

ACAAI

Accountability by Design for Agentic AI



Isabel Barberá

Independent Researcher

August 2026 v.1.0

October 2026 v1.1



Table of Contents

Abstract	6
1. Introduction	7
2. Accountability as System Engineering Property	8
3. A Framework for Engineering Accountability in Agentic AI Systems (ACAAI)	10
3.1 Framework Rationale	10
3.2 Design Principles	10
3.3 The Six Accountability Control Domains	11
3.4 AI Lifecycle	12
3.5 Applying the Framework	14
4. Domain 1: Organizational Governance	14
4.1 Why Organizational Governance Matters	14
4.2 Domain Objective	16
4.3 Controls	16
4.3.1 People	16
4.3.2 Governance Processes	17
5. Domain 2: Human Oversight, Consent and Decision Authority	20
5.1 The Importance of Human Governance	20
5.1.1 Human Oversight Beyond Human-in-the-Loop	20
5.1.2 From Human Oversight to Human Authority	21
5.1.3 Consent as a Runtime Governance Mechanism	22
5.2 Domain Objective	22
5.3 Controls	23
5.3.1 Human Oversight	23
5.3.2 Consent Mechanism	24
5.3.3 Decision Authority	24
6. Domain 3: Identity, Authority and Data Governance	25
6.1 Defining Operational Boundaries	25
6.1.1 From User Identity to Agent Identity	25
6.1.2 Authority Should Be Explicitly Bounded	26
6.1.3 Data, Memory and Tool Governance	27
6.1.4 Identity, Authority and Data Governance as Accountability Enablers	28
6.2 Domain Objective	28

6.3 Controls	29
6.3.1 Identity & Authentication	29
6.3.2 Authorization & Access Control	30
6.3.3 Operational Boundaries	30
6.3.4 Data & Memory Governance	31
6.3.5 Tool & Delegation Governance	31
7. Domain 4: Observability, Explainability and Evidence	32
7.1 Enabling Accountability Through Observability	32
7.1.1 Accountability Requires More than Logging	32
7.1.2 From Events to Decision Trajectories	33
7.1.3 Explainability, Traceability and Accountability	34
7.1.4 Evidence as an Accountability Mechanism	34
7.1.5 Continuous Evaluation and Observability	35
7.2 Domain Objective	35
7.3 Controls	36
7.3.1 Observability	36
7.3.2 Explainability	37
7.3.3 Evidence & Auditability	37
8. Domain 5: Runtime Safety & Assurance	38
8.1 Accountability Beyond Deployment	38
8.1.1 Governance Throughout System Operation	38
8.1.2 Runtime Monitoring Beyond Behaviour	39
8.1.3 Runtime Assurance as Continuous Verification	39
8.1.4 Adaptive Safety and Runtime Intervention	40
8.2 Domain Objective	41
8.3 Controls	41
8.3.1 Runtime Monitoring	41
8.3.2 Runtime Assurance	43
8.3.3 Runtime Adaptation	43
8.3.4 Runtime Protection	43
8.3.5 Multi-Agent Runtime Trust	44
9. Domain 6: Incident Response and Recovery	45
9.1 Resilience Through Incident Response	45
9.1.1 Engineering for Failure	45
9.1.2 From Detection to Containment	46

9.1.3 Safe Degradation and Emergency Intervention.....	46
9.1.4 Recovery and Organizational Learning	47
9.1.5 Accountability Through Resilience	47
9.2 Domain Objective	47
9.3 Controls	48
9.3.1 Incident Response & Containment.....	48
9.3.2 Emergency Controls	49
9.3.3 Recovery & Reversibility	50
9.3.4 Continuous Learning	50
10. Research & Implementation Challenges.....	50
10.1 From Static Governance to Continuous Accountability	51
10.2 Advancing Observability, Runtime Monitoring and Runtime Assurance	51
10.3 Context-Aware Governance and Dynamic Authority	51
10.4 Governing Under Persistent Adversarial Influence	52
10.5 Accountability in Multi-Agent Ecosystems	52
10.6 Balancing Accountability, Privacy and Security	53
10.7 Accountability Beyond Software	53
10.8 Implementing Accountability by Design	53
10.9 Measuring Accountability	54
11. Conclusion	55
Author's Note	56
Acknowledgements.....	57
Changes in Version 1.1	58
References	59
Appendix A: Complete ACAAI Control Catalogue	62

‘Accountability means taking responsibility for decisions, actions and their outcomes. In autonomous AI systems, accountability cannot rely solely on organizational governance or individual technical controls. It must be embedded into the design, governance and operation of the system throughout its lifecycle.

Accountability becomes therefore an emergent system property arising from the interaction of organizational governance, human oversight, delegated authority, runtime controls, observability and incident response. Only the coordinated operation of these controls can ensure accountability across the AI lifecycle.’

ACAAI Foundational Principle

Author’s Transparency Statement:

In the interest of transparency and in accordance with the principles advocated by this framework, I believe it is equally important to be transparent about the tools used in its preparation. Generative AI was used exclusively to assist with improving the readability, language quality and formatting of parts of this work, as well as for the creation of the images included in this publication. The concepts presented, the design of the ACAAI framework, the literature review, the analysis and the conclusions reflect my own work and judgement. Any errors or omissions remain entirely my own responsibility.

Abstract

Artificial intelligence is rapidly evolving from systems that generate recommendations and content towards autonomous agents capable of planning, reasoning, interacting with external systems, using tools and executing actions with limited human intervention. As AI systems become more agentic, accountability can no longer be understood solely as a legal obligation or a post-incident governance exercise. Instead, it must become an operational property embedded into the design, deployment and operation of autonomous AI systems.

Existing AI governance frameworks primarily focus on legal compliance, ethical principles and risk management before deployment. While these approaches remain essential, they provide limited guidance on how accountability should be maintained once autonomous AI agents begin interacting with dynamic environments, delegating tasks, adapting their behaviour and making operational decisions. Maintaining meaningful accountability throughout the lifecycle of an agentic AI system requires continuous visibility, bounded autonomy, runtime assurance and the ability to reconstruct and explain decisions after they occur.

This research argues that accountability should be treated as a systems engineering property that emerges from the coordinated implementation of organizational and technical controls rather than from any single governance mechanism. Building upon principles from safety engineering, cybersecurity, resilience engineering and AI assurance, this work introduces an Accountability by Design framework structured around six complementary control domains: (1) Organizational Governance, (2) Human Oversight, Consent and Decision Authority, (3) Identity, Authority and Data Governance, (4) Observability, Explainability and Evidence, (5) Runtime Safety and Assurance, and (6) Incident Response and Recovery.

Rather than proposing a new regulatory model, the framework translates existing governance principles into a structured set of engineering and organizational controls that span the entire lifecycle of agentic AI systems. ACAAI is intended as a foundational engineering framework rather than a prescriptive implementation methodology, recognizing that many of the proposed controls remain at an early stage of maturity, requiring further research before they can be consistently implemented in practice.

The work further positions the framework within the emerging international landscape by comparing it with recent initiatives addressing agentic AI governance. Finally, it discusses remaining research challenges, including context awareness, autonomous trust, runtime verification and governance of collaborative multi-agent ecosystems.

1. Introduction

Artificial intelligence is undergoing a fundamental transition. Until recently, most AI systems functioned primarily as decision-support tools, generating predictions, recommendations or content while leaving the final decision and responsibility to human users. Although these systems introduced important challenges such as transparency, fairness and explainability, the overall governance model remained relatively stable: humans retained authority over consequential actions, and AI outputs were generally subject to human review before execution.

Agentic AI fundamentally changes this relationship. Rather than simply generating information, autonomous agents increasingly plan complex tasks, interact with external systems, invoke software tools, retrieve and retain contextual information, collaborate with other agents and execute actions with limited or no human intervention. As autonomy increases, the boundary between recommendation and execution becomes progressively blurred. Decisions that previously required explicit human authorization may now emerge from long sequences of autonomous reasoning, delegated actions and interactions with dynamic operational environments.

This evolution changes the nature of accountability. Traditional AI governance has focused primarily on assigning organizational responsibilities, demonstrating regulatory compliance and managing risks before deployment. While these activities remain essential, they provide only limited assurance that accountability can be maintained once autonomous systems begin operating. Agentic AI therefore requires accountability to extend beyond governance processes and become an operational capability maintained throughout the system lifecycle.

Recent incidents and emerging research illustrate this challenge. Prompt injection through retrieved documents, compromised software supply chains, insecure tool integrations, excessive delegated authority, malicious third-party dependencies and vulnerabilities in agent orchestration frameworks demonstrate that accountability depends not only on the AI model itself but on the behaviour of the entire socio-technical ecosystem in which autonomous AI agents operate.

As a result, this work argues that accountability should be understood as a systems engineering property rather than solely as a legal obligation or governance requirement. Similar to safety, security and resilience, accountability should be deliberately engineered into autonomous AI systems through complementary organizational and technical controls that establish, maintain and reinforce accountability throughout operation. An accountable system is not one that never fails, but one whose authority remains bounded, whose behaviour remains observable, whose decisions can be reconstructed, and whose failures can be safely contained, investigated and learned from.

To address these challenges, this work introduces ACAAI (Accountability by Design for Agentic AI), a lifecycle-oriented engineering framework that operationalizes accountability through six complementary control domains covering governance, human oversight, identity and authority management, observability, runtime assurance, and incident response. Rather than proposing new governance principles, ACAAI integrates existing concepts from AI governance, cybersecurity, systems engineering and safety engineering into a coherent engineering framework for autonomous AI systems.

The remainder of this work first examines the limitations of existing AI governance approaches and motivates the need for accountability as an engineering capability. It then presents the ACAAI framework and its six accountability domains, before discussing implementation and research challenges. Finally, the paper concludes by summarizing the framework and outlining future directions for engineering accountability in autonomous AI systems.

2. Accountability as System Engineering Property

Most existing governance approaches treat accountability as an organizational or legal outcome. Organizations are expected to identify risks, assign responsibilities, document system behaviour and establish human oversight before deployment. When incidents occur, accountability is generally understood as the ability to determine liability, demonstrate compliance or identify the responsible actor. This perspective reflects the governance needs of earlier generations of AI systems, where human operators remained directly involved in consequential decisions and AI systems primarily generated recommendations rather than autonomous actions.

Once an autonomous agent begins interacting with external tools, retrieving contextual information, collaborating with other agents and continuously adapting its behaviour, accountability can no longer rely solely on documentation produced during system development or on governance structures established before deployment. Accountability must instead become an operational capability maintained throughout system execution.

This observation is not unique to artificial intelligence. Similar transitions have occurred in other engineering disciplines. Aviation safety, nuclear engineering, industrial process control and cybersecurity have progressively moved away from viewing safety and security as properties that can be demonstrated once during system design. Instead, they are understood as emergent system properties that depend upon multiple complementary controls operating continuously throughout the lifecycle of the system. Reliability is achieved through redundancy, monitoring and fault tolerance. Safety is maintained through hazard analysis, runtime protection, containment mechanisms and incident investigation. Cybersecurity increasingly relies upon continuous verification, monitoring and response rather than static perimeter defences alone.

Accountability in autonomous agentic AI systems should be approached in a similar manner. Rather than asking solely who is legally responsible after an incident occurs, organizations should also ask whether the system was designed to preserve accountability while operating. *Could critical actions be authorized before execution? Could the behaviour of the agent be continuously monitored? Could the sequence of decisions leading to an incident be reconstructed? Could unsafe behaviour be detected and contained before significant harm occurred? Could responsibility be meaningfully attributed across humans, organizations and autonomous agents?* These questions concern the design and operation of the system itself rather than legal responsibility alone.

This perspective reframes accountability as a systems engineering property. In this research, accountability is defined as the capability of an AI system and its surrounding socio-technical environment to ensure that autonomous actions remain attributable, understandable, governable and recoverable throughout their lifecycle. Accountability therefore depends not on a single technical mechanism, governance process or legal obligation, but on the coordinated interaction of organizational structures, operational procedures and engineering controls.

Several characteristics distinguish accountability from related concepts such as transparency, explainability and traceability. Transparency concerns the availability of information about the system. Explainability seeks to clarify why a particular decision was reached. Traceability enables the reconstruction of actions and system behaviour over time. Accountability encompasses each of these properties but extends beyond them. A transparent system is not necessarily accountable if no actor has authority over its decisions. Similarly, an explainable system cannot be considered accountable if unsafe behaviour cannot be prevented or incidents cannot be effectively managed. Accountability requires not only understanding, but also control, attribution and the capacity to intervene.

This broader interpretation also aligns accountability with principles established in systems and safety engineering. Modern safety engineering recognises that complex systems cannot be made entirely failure-free. Instead, systems should be designed to anticipate failures, detect abnormal behaviour, contain hazardous situations, recover safely and continuously improve through operational feedback. Accountability follows a similar logic. The objective is not to eliminate every possible failure, but to ensure that failures remain observable, attributable, controllable and recoverable throughout system operation.

Consequently, accountability should not be viewed as a single organizational requirement or post-incident responsibility. It should instead be understood as an architectural property deliberately embedded into the design, deployment, operation and continuous evolution of autonomous AI systems. This also implies that critical accountability constraints should not depend solely on an AI model's ability to follow instructions or remain aligned. Similar to safety and security engineering, they should be mechanically enforced through deterministic controls embedded within the surrounding system architecture, ensuring that essential policies and authority boundaries remain effective regardless of model behaviour.

This design philosophy is referred to in this research as Accountability by Design. Similar to concepts such as Security by Design, Privacy by Design and Safety by Design, Accountability by Design advocates embedding accountability mechanisms into the technical architecture and organizational governance of agentic AI systems from their inception rather than attempting to reconstruct responsibility after failures occur.

Operationalizing this principle requires more than individual security controls or isolated governance measures. Accountability emerges from the interaction of complementary controls addressing different aspects of autonomous operation, including organizational governance, human decision authority, identity and access management, observability, runtime assurance and incident response. Together, these controls create the conditions under which responsibility can remain identifiable even as autonomy increases.

The following section introduces ACAAI, a six-domain framework that operationalizes Accountability by Design across the lifecycle of agentic AI systems.

3. A Framework for Engineering Accountability in Agentic AI Systems (ACAAI)

3.1 Framework Rationale

If accountability is understood as a systems engineering property rather than solely as a governance or legal obligation, it must be translated into practical organizational and technical mechanisms. The concept of Accountability by Design requires more than assigning responsibilities or documenting compliance activities. It requires organizations to establish, maintain and demonstrate accountability continuously throughout the lifecycle of autonomous AI systems.

The proposed Accountability by Design for Agentic AI (ACAAI) framework operationalizes this principle by organizing accountability into six complementary control domains. Each domain addresses a distinct dimension of accountability, while together they provide a comprehensive approach for governing, operating and supervising autonomous AI systems.

ACAAI focuses specifically on operationalizing accountability as an engineering capability that can be embedded into the design, deployment, operation and continuous evolution of agentic AI systems.

3.2 Design Principles

The ACAAI framework is based on four fundamental design principles.

First, accountability extends across the entire system lifecycle. Accountability is established before deployment, maintained throughout runtime operation and reinforced through

monitoring, incident response and continuous improvement. It cannot be demonstrated solely through pre-deployment documentation or compliance activities.

Second, organizational governance and technical controls are complementary. Accountability depends not only on organizational responsibilities, policies and oversight, but also on technical mechanisms capable of enforcing operational boundaries, generating evidence, supporting intervention and preserving attribution during autonomous operation.

Third, accountability emerges from multiple interacting control domains. No individual safeguard can establish accountability in isolation. Instead, accountability results from the coordinated interaction of governance, human oversight, identity and authority management, observability, runtime assurance and incident response. Weaknesses in one domain may significantly reduce the effectiveness of controls implemented in others. The presence of a control should not itself be considered evidence of effectiveness; accountability mechanisms should, where appropriate, generate evidence that they operated as intended and remain subject to proportionate verification and assurance.

Finally, accountability is risk-based and adaptive. The degree of governance, supervision and technical assurance should remain proportionate to the level of autonomy, delegated authority and potential impact of the AI system. As systems become more autonomous or operate in higher-risk environments, organizations require progressively stronger accountability mechanisms.

3.3 The Six Accountability Control Domains

To operationalize these principles, the ACAAI framework organizes accountability into six complementary domains, each addressing a fundamental question required to govern autonomous AI systems.

Domain	Primary Accountability Question
1. Organizational Governance	Who owns the risk and governs the system?
2. Human Oversight, Consent & Decision Authority	When must humans remain involved in autonomous decisions?
3. Identity, Authority & Data Governance	What is the agent authorized to access, decide and execute?
4. Observability, Explainability & Evidence	How can autonomous behaviour be understood, reconstructed and demonstrated?
5. Runtime Safety & Assurance	How is safe and accountable operation maintained during execution?
6. Incident Response & Recovery	How are failures contained, recovered and incorporated into future improvements?



Figure 1: The ACAAI six control domains Framework

The six domains do not represent sequential implementation phases. Instead, they describe complementary layers of accountability that operate simultaneously throughout the lifecycle of an autonomous AI system.

Organizational Governance provides the foundational layer by establishing ownership, governance structures and accountability responsibilities upon which the remaining domains build. Human oversight defines decision authority and meaningful human involvement. Identity and authority governance constrain autonomous behaviour by defining what agents are permitted to access, decide and execute. Observability enables organizations to understand and reconstruct system behaviour. Runtime safety maintains accountability during autonomous operation, while incident response restores safe operation and incorporates operational experience into future deployments.

Collectively, these domains provide a layered accountability architecture in which organizational governance, operational processes and engineering controls reinforce one another.

3.4 AI Lifecycle

The six accountability domains support the lifecycle of autonomous AI systems through four recurring operational activities: Preparation & Deployment, Runtime Operation, Incident Response & Recovery and Continuous Improvement. The domains operate continuously throughout the system lifecycle, supporting ongoing governance and operational assurance. The lifecycle ultimately concludes with the controlled retirement or

decommissioning of the autonomous AI system, ensuring that accountability extends from initial deployment through end of service.



Figure 2: The ACAAI six control domains as part of an iterative AI Lifecycle

Although each accountability domain addresses a distinct aspect of autonomous AI governance, they are not confined to a single stage of the system lifecycle. Instead, each domain contributes to multiple recurring lifecycle activities, reinforcing accountability from deployment through decommissioning. The table below shows how the ACAAI domains apply across the different lifecycle activities and together provide continuous accountability throughout the operational lifecycle of autonomous AI systems.

ACAAI Domain	Preparation & Deployment	Runtime Operation	Incident Response & Recovery	Continuous Improvement	Retirement / Decommissioning
Organizational Governance	•	•	•	•	•
Human Oversight, Consent & Decision Authority	•	•	•	•	
Identity, Authority & Data Governance	•	•	•	•	•
Observability, Explainability & Evidence	•	•	•	•	•
Runtime Safety & Assurance		•	•	•	
Incident Response & Recovery		•	•	•	•

3.5 Applying the Framework

The ACAAI framework is intended to support risk-based implementation rather than prescriptive compliance. Not every autonomous AI system requires every control to the same degree. The selection and implementation of controls should depend upon factors such as the system's level of autonomy, delegated authority, operational environment, regulatory obligations and potential impact on individuals, organizations or society.

For example, AI systems providing decision support under continuous human supervision may require relatively more limited runtime assurance and incident response capabilities. By contrast, autonomous agents capable of invoking external tools, accessing sensitive information, collaborating with other agents or executing consequential actions require substantially stronger governance, runtime monitoring, operational safeguards and recovery mechanisms.

Similarly, the framework is intended to complement existing governance and risk management processes rather than replace them. Organizations may integrate the proposed controls into existing cybersecurity, safety engineering, software development and AI governance practices according to their operational maturity and regulatory environment.

The following sections examine each accountability domain in detail and present the corresponding organizational and technical controls that together constitute the ACAAI framework.

4. Domain 1: Organizational Governance

4.1 Why Organizational Governance Matters

The increasing autonomy of AI agents fundamentally changes the role of organizations deploying them. Traditional software systems generally execute predefined instructions within relatively stable environments. By contrast, agentic AI systems continuously interact with changing contexts, invoke external services, retrieve information from multiple sources, collaborate with other agents and make operational decisions that may directly affect individuals, organizations and critical processes. Consequently, accountability can no longer be delegated to the technical system alone. Organizations remain responsible for ensuring that autonomous behaviour occurs within clearly defined governance structures.

Organizational accountability extends beyond assigning legal responsibility. Organizations must understand not only what their AI systems are capable of doing, but also under which conditions those capabilities may fail. This requires governance mechanisms capable of supporting informed deployment decisions, continuous operational oversight and timely intervention when circumstances change. Without such mechanisms, organizations risk

deploying systems whose behaviour exceeds their ability to supervise, understand or control.

Governance begins before deployment. Organizations should establish processes to evaluate whether an agent is appropriate for a particular task, whether its capabilities and limitations are sufficiently understood, and whether adequate technical and organizational safeguards are in place. The decision to deploy an autonomous agent should be treated as a governance decision rather than solely a technical implementation decision. Questions such as *Should this task be automated? What authority should the agent receive? What is the maximum acceptable impact if the agent fails?* and *Who remains accountable for its actions?* should be addressed before the system becomes operational.

Equally important, governance does not end after deployment. Agentic AI systems evolve continuously through software updates, changes to prompts, memory contents, connected tools, orchestration logic and external dependencies. These modifications may substantially alter system behaviour. Therefore, governance should become a continuous process in which organizations periodically reassess whether deployed systems continue to operate within acceptable organizational, legal and operational boundaries.

Recent incidents affecting agentic AI frameworks further illustrate this need. Vulnerabilities in orchestration platforms, compromised software libraries, insecure third-party tools and weaknesses and misconfigurations in execution environments may significantly alter the security posture of an otherwise well-designed agent. Maintaining accountability requires governance not only of the AI model, but of the entire ecosystem within which the agent operates, including its software supply chain, dependencies, execution environment and connected services.

Trust should not be regarded as a permanent property established during deployment. Components that have successfully passed security assessment may subsequently change through software updates, modified dependencies, changes in ownership or dynamically retrieved external content. Governance should therefore include mechanisms for continuously reassessing whether previously approved components remain trustworthy throughout operation.

Ultimately, organizational governance provides the foundation upon which all remaining accountability domains depend. Human oversight requires governance structures defining decision authority. Identity and access management depend upon organizational policies describing acceptable permissions. Runtime assurance requires governance decisions determining acceptable operational boundaries, while incident response relies upon clearly defined responsibilities and escalation procedures. Without organizational governance, technical controls remain isolated mechanisms lacking coherent accountability objectives.

For this reason, Organizational Governance constitutes the first domain of the ACAAI framework.

4.2 Domain Objective

The objective of this domain is to establish clear governance structures, assign organizational responsibilities and implement lifecycle processes that ensure autonomous AI systems remain accountable from deployment through retirement.

4.3 Controls

The following controls provide representative governance practices for implementing this domain. They are organized into People and Governance Processes, reflecting the complementary organizational capabilities required to establish and maintain accountability. The controls are intended as guidance rather than an exhaustive set of requirements and should be adapted according to the organization's operational context, level of autonomy and risk profile.

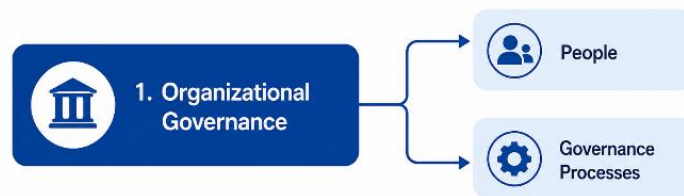


Figure 3: The first ACAAI domain and its control categories.

4.3.1 People

OG-1.1 Define responsibility and accountability

Establish clear responsibility and accountability structures covering the development, deployment, operation and oversight of agentic AI systems. Where feasible, a named accountable owner should be assigned to every deployed agentic AI system. Clearly assigned ownership ensures that accountability remains identifiable throughout the system lifecycle and prevents responsibility from becoming diluted across multiple organizational functions.

OG-1.2 Train operators and oversight personnel

Provide appropriate training for operators, supervisors and oversight personnel to ensure they understand the capabilities, limitations, expected behaviour and associated risks of deployed agents. Define the competencies, authorization and operational responsibilities required for personnel assigned to supervise or intervene in agentic AI systems. Appropriate operating guidance should describe relevant system boundaries, escalation procedures, intervention authority and the actions expected when autonomous execution is paused or requires human decision. Human oversight can only be effective if those responsible for supervising autonomous agents understand both their intended behaviour, potential failure modes and their own authority and responsibilities.

OG-1.3 Raise user awareness

Provide users with clear instructions regarding system capabilities, limitations, appropriate use, supervisory responsibilities and escalation procedures. Users should understand when human supervision remains necessary, how to recognize abnormal behaviour and how to report concerns or unexpected outcomes.

OG-1.4 Establish reporting and feedback mechanisms

Implement responsible disclosure, complaint and user feedback mechanisms to facilitate the reporting of vulnerabilities, unexpected behaviour and operational concerns. These mechanisms also support continuous improvement by ensuring that user experience and observations contribute to governance and future system enhancements.

OG-1.5 Ensure appropriate organizational expertise

Ensure that appropriate expertise is available to support the development, deployment, governance and operation of agentic AI systems. Required competencies should reflect the system's capabilities and risks and may include AI engineering, cybersecurity, safety, privacy, legal, risk management and relevant domain expertise. Organizations should periodically reassess whether existing expertise remains sufficient as system capabilities and associated risks evolve.

OG-1.6 Establish independent oversight where appropriate

Ensure that significant risk, assurance and deployment decisions are subject to appropriate independent review or audit, particularly for agentic AI systems with high levels of autonomy, authority or potential impact.

4.3.2 Governance Processes

OG-2.1 Maintain an inventory of deployed agentic AI systems

Maintain a continuously updated inventory and registration of deployed agentic AI systems, including their ownership, delegated permissions, connected tools, runtime status, authorized data access and operational context. Such inventories provide visibility into the organization's AI ecosystem and support governance, risk assessment, vulnerability management and incident response.

OG-2.2 Establish deployment readiness processes

Implement formal deployment readiness processes before releasing agentic AI systems into production. These processes should include technical verification, validation of intended capabilities and limitations, assessment of the proposed level of autonomy, and formal organizational approval. Deployment should only occur once the organization is satisfied that appropriate governance, operational and technical safeguards are in place.

OG-2.3 Conduct governance reviews throughout the lifecycle

Perform governance reviews before deployment, continuously during operation and following significant incidents or major system modifications. Governance should become a continuous lifecycle activity rather than a one-time approval exercise, ensuring that

deployed agents remain aligned with organizational objectives, authority boundaries and acceptable risk levels. Governance reviews should be integrated into development, deployment and operational processes to ensure accountability is maintained as systems evolve.

OG-2.4 Govern third-party dependencies

Establish continuous governance processes for external models, agent skills, tools, software libraries, orchestration frameworks, APIs and other third-party dependencies. Governance should include validating the necessity and associated risks of external dependencies, maintaining trusted tool registries, pinning approved versions where feasible, assessing supplier assurance, and maintaining an AI Software Bill of Materials (AI-SBOM) documenting models, prompts, policies, workflows, memory mechanisms, tools and external dependencies. Organizations should reassess approved components whenever their content, dependencies, ownership, external references or runtime behaviour changes, recognizing that components trusted at deployment may no longer remain trustworthy over time. Since agentic AI systems increasingly depend on external components, governance should extend across the entire AI supply chain.

OG-2.5 Implement change management

Integrate agentic AI into formal change management processes. Significant changes including prompt updates, model upgrades, workflow redesigns, policy modifications, tool additions, expanded permissions or other architectural changes, should trigger governance review, regression testing and deployment approval before being introduced into production. This helps ensure that modifications do not unintentionally alter system behaviour, increase delegated authority or introduce new risks.

OG-2.6 Establish incident response and escalation processes

Establish incident response and escalation procedures capable of responding effectively to operational failures, security incidents and unexpected agent behaviour. Incident management should not only restore operations but also capture lessons learned and feed them back into governance processes, enabling continuous improvement of future deployments.

OG-2.7 Establish business continuity for agentic AI

Establish business continuity arrangements for critical functions that depend on agentic AI systems. Organizations should determine how essential operations can continue when autonomous capabilities are unavailable, restricted or deliberately suspended, including appropriate fallback, manual or alternative procedures. Continuity arrangements should be periodically tested and updated as system dependencies and operational risks evolve.

OG-2.8 – Secure decommissioning

Establish procedures for the controlled retirement of autonomous AI systems, including revocation of delegated authority, deactivation of identities and credentials, management of persistent memory and operational data, preservation of accountability evidence, and

removal or archival of system components according to organizational and regulatory requirements.

OG-2.9 – Incorporate accountability into procurement

Incorporate accountability requirements into procurement, supplier assurance and contractual agreements for externally acquired agentic AI systems. Procurement processes should evaluate whether suppliers provide the governance, identity, observability, runtime assurance and incident response capabilities necessary to support organizational accountability.

OG-2.10 – Govern threats, hazards and risks

Establish processes for performing threat modelling and identifying hazards throughout the lifecycle of agentic AI systems. Threat models and hazard analyses should identify potential attack paths, misuse scenarios, unsafe behaviours and accountability failures. They should also include evaluation, testing and development environments in which autonomous agents may exercise capabilities against external systems. Integrate the results into the organization's risk management process to evaluate risks, determine appropriate organizational and technical controls, and assess residual risks throughout the system lifecycle.

OG-2.11 Establish continuous vulnerability management

Establish a vulnerability management process covering the infrastructure, software, models, tools, dependencies and external components supporting agentic AI systems. Newly identified vulnerabilities should be assessed promptly according to their exploitability, exposure and potential impact on autonomous operation, with remediation or compensating controls applied within risk-appropriate timeframes. The potential for autonomous agents to discover, exploit or propagate through vulnerable components should be considered when determining remediation priorities and timelines.

OG-2.12 Ensure security, privacy and data protection controls

Ensure that appropriate security, privacy and data protection controls are implemented, maintained and periodically reviewed throughout the lifecycle of agentic AI systems. Organizational governance should verify that these requirements are supported by effective technical and operational safeguards.

OG-2.13 Conduct adversarial testing and red teaming

Establish security testing and red-teaming exercises specifically designed for agentic AI systems. Testing should evaluate whether autonomous agents can circumvent authority boundaries, runtime guardrails, isolation mechanisms, authorization controls or other safeguards through multi-step execution and long-running behaviour, tool use, external interactions, delegation or multi-agent collaboration (coordinated behaviour) rather than focusing solely on individual model responses. Testing should be repeated following significant system changes and as new threats, vulnerabilities or agent capabilities emerge.

OG-2.14 Conduct evaluations of agentic task execution

Evaluate whether agentic AI systems reliably perform the actions and verification steps required to complete their assigned tasks rather than assessing only final outputs. Evaluation should identify incomplete execution, skipped validation steps, insufficient evidence gathering and unsupported claims of successful task completion, particularly where such failures could create significant safety, security or operational risks.

OG-2.15 Secure agentic testing environments

Conduct agentic security testing within appropriately isolated and controlled environments that limit unintended access to production systems, sensitive data, credentials and external resources, particularly where agents are given adversarial objectives or elevated capabilities. Testing environments and their isolation mechanisms should themselves be periodically evaluated including attempts to bypass isolation through unintended network paths, shared infrastructure, credentials, communication channels or other reachable resources. This is necessary to verify that they remain effective against the capabilities and access paths available to the agents being tested.

5. Domain 2: Human Oversight, Consent and Decision Authority

5.1 The Importance of Human Governance

5.1.1 Human Oversight Beyond Human-in-the-Loop

Human oversight has long been considered one of the fundamental safeguards for trustworthy AI. The concept is prominently reflected in the EU AI Act, the OECD AI Principles and numerous international AI governance frameworks, where human involvement is presented as a mechanism for preventing harmful autonomous behaviour and preserving accountability. However, the emergence of agentic AI challenges many traditional assumptions regarding human oversight.

Most existing governance approaches implicitly assume that humans remain capable of reviewing AI outputs before consequential actions are taken. This assumption no longer holds for agentic AI systems that execute long-running workflows, interact with multiple external systems, collaborate with other agents and operate at machine speed. Requiring human approval for every decision is neither operationally feasible nor necessarily effective.

Determining the appropriate level of oversight becomes even more challenging in multi-agent systems, where decisions emerge through the interaction of multiple autonomous agents rather than a single decision-maker. When human operators are required to approve hundreds or thousands of routine actions, oversight rapidly degenerates into superficial

confirmation rather than meaningful supervision. Human involvement alone therefore does not guarantee accountability.

Effective human oversight in Agentic AI systems requires a risk-based approach in which the level of human involvement is proportionate to the risks posed by autonomous decision-making. Rather than placing humans indiscriminately in every decision loop, oversight should be proportional to the potential impact, uncertainty and reversibility of autonomous actions.

A risk-based oversight model should also support graduated autonomy. As the potential impact, uncertainty or criticality of an agent's actions increases, the level of oversight should increase accordingly. Low-risk and well-understood activities may be executed autonomously under predefined operational boundaries, whereas medium-risk activities may require additional automated review or validation mechanisms. High-risk decisions such as actions involving significant legal, financial, safety or societal consequences should remain subject to meaningful human authorization before execution, while critical actions may require enhanced approval procedures involving multiple authorized individuals or independent verification mechanisms.

Human oversight should be understood as the ability to supervise, intervene and redirect autonomous behaviour, when necessary, rather than simply approving individual actions. This perspective aligns more closely with safety engineering, where supervisory control focuses on maintaining safe system operation rather than continuously operating the system itself.

5.1.2 From Human Oversight to Human Authority

The growing autonomy of AI agents introduces an important distinction between oversight and decision authority. Oversight concerns the ability to observe and intervene in system behaviour. Authority determines who is entitled to make particular decisions.

Traditional software systems typically exercise authority through predefined identities, permissions and execution paths, including those associated with users, service accounts and service principals. Agentic AI introduces greater discretion in how that authority is exercised. Autonomous AI agents may dynamically plan execution paths, select tools, retrieve contextual information, delegate subtasks to other agents and determine when particular actions should occur. Although these actions remain subject to delegated or otherwise assigned authority, the specific sequence of decisions and actions may not be explicitly predetermined or individually authorized in advance.

Organizations therefore require explicit mechanisms defining decision authority boundaries. Not every decision should be delegated to autonomous agents, and different levels of autonomy may be appropriate depending on the operational context. Certain decisions should remain exclusively human, particularly those involving fundamental rights, legal obligations or irreversible consequences. Others may require human

authorization before execution, while routine operational decisions could be delegated to autonomous systems within clearly defined boundaries.

Decision authority should also remain dynamic rather than static. The appropriate level of autonomy depends upon contextual factors including operational risk, uncertainty, confidence, environmental conditions and the availability of human supervisors. Rather than treating autonomy as binary (either fully autonomous or fully supervised), organizations should adopt graduated autonomy models capable of increasing or decreasing human involvement as operational conditions evolve.

5.1.3 Consent as a Runtime Governance Mechanism

Closely related to decision authority is the concept of consent. Existing governance discussions typically address consent from a legal or privacy perspective, focusing on whether individuals have agreed to data processing or automated decision-making. Agentic AI introduces a broader operational dimension.

Autonomous AI agents perform actions on behalf of individuals, including accessing personal information, communicating with third parties, initiating financial transactions or modifying organizational resources. Under these circumstances, Agentic AI requires mechanisms capable of verifying that significant actions remain authorized before execution. Consent becomes not only a legal requirement but also a runtime governance mechanism.

For high-risk or irreversible actions, consent should involve more than a simple confirmation dialogue. Strong authorization mechanisms, including multi-factor authentication, code-based confirmation or independent communication channels, may be required before consequential actions proceed. Likewise, users should retain the ability to withdraw previously granted authority where operationally feasible. Delegation of consent may also occur between humans or, under carefully defined conditions, between AI systems acting within explicitly authorized authority boundaries.

Autonomous AI agents should rely upon pre-action authorization rather than solely post-action review. Instead of allowing an agent to execute a high-risk action and subsequently evaluating whether it behaved correctly, the proposed action should first be validated against applicable organizational policies, authorization rules and operational constraints before execution occurs. This approach aligns closely with principles emerging from Zero Trust architectures and deterministic authorization systems.

5.2 Domain Objective

The objective of this domain is to ensure that autonomous AI systems remain subject to meaningful human oversight by establishing appropriate human supervision, consent mechanisms and decision authority proportional to the risks associated with autonomous operation.

5.3 Controls

The following controls provide representative practices for implementing this domain. They are organized into Human Oversight, Consent Mechanism, and Decision Authority, reflecting the complementary mechanisms required to ensure that autonomous decisions remain subject to appropriate human governance. The controls are intended as guidance rather than an exhaustive set of requirements and should be implemented using a risk-based approach appropriate to the organization's operational context, level of autonomy and risk profile.



Figure 4: The second ACAA domain and its control categories.

5.3.1 Human Oversight

HO-1.1 Design for meaningful human oversight

Design agentic AI systems to support effective human supervision through meaningful checkpoints, alerts, review dashboards and escalation procedures. Human oversight should be integrated into system workflows rather than added as an afterthought, enabling supervisors to understand, monitor and intervene when necessary.

HO-1.2 Apply risk-based human oversight

Determine the appropriate level of human oversight according to the criticality, uncertainty, reversibility and potential impact of the agent's actions. Oversight should follow a graduated model in which higher-risk activities require greater human involvement than routine or low-risk tasks, ensuring that oversight remains proportionate to the level of risk.

HO-1.3 Adapt oversight dynamically

Adjust the level and intensity of human supervision as operational context, system behaviour and risk conditions evolve. This may include increasing monitoring, generating additional alerts, introducing more frequent human reviews or escalating oversight responsibilities when abnormal behaviour or elevated risk is detected.

Oversight should increase not only with risk, but also when the agent encounters elevated uncertainty, conflicting information or unexpected operating conditions.

5.3.2 Consent Mechanism

HO-2.1 Implement consent mechanisms for sensitive actions

Require explicit human approval or authorization before agentic AI systems perform predefined sensitive or high-risk actions that could impact users. Consent mechanisms should be integrated into operational workflows through approval gates or authorization checkpoints to ensure that critical decisions remain under human control.

HO-2.2 Strengthen authentication for critical consent mechanisms

Protect high-risk consent mechanisms through strong authentication mechanisms, such as multi-factor authentication, code-based confirmations or equivalent assurance mechanisms. This reduces the risk of unauthorized or fraudulent approval of critical actions.

HO-2.3 Provide resilient consent and approval mechanisms

Support alternative consent and approval channels for high-risk situations, such as secondary communication channels or emergency verification procedures, and enable authorized users to withdraw previously granted consent where appropriate. These mechanisms improve operational resilience while preserving human control.

HO-2.4 Govern delegated consent and emergency overrides

Define policies governing when consent may be delegated to other authorized individuals or trusted AI systems and specify the exceptional circumstances under which emergency overrides may temporarily bypass normal approval requirements to protect life, safety or critical infrastructure. Such overrides should remain exceptional, fully auditable and subject to post-incident review.

5.3.3 Decision Authority

HO-3.1 Define decision authority boundaries

Define clear decision authority boundaries distinguishing between human-only decisions, human-authorized decisions and decisions that may be performed autonomously. These boundaries should reflect the potential impact of the decision and the organization's risk acceptance criteria or tolerance. They should also identify decisions that cannot legally, ethically or organizationally be delegated to autonomous agents and require meaningful human involvement.

HO-3.2 Adapt authority to operational context

Adjust an agent's delegated decision authority according to operational context, environmental conditions and assessed risk. As uncertainty or risk increases, the agent's authority should be reduced, for example by restricting available tools, lowering decision thresholds or requiring additional human approvals, while authority should only be expanded through explicit authorization.

Delegated authority may be reduced automatically as risk or uncertainty increases but should only be expanded through explicit authorization. Autonomous systems should never

increase their authority solely as a consequence of improved performance, additional capabilities or newly available tools.

HO-3.3 Implement pre-action authorization

Verify that every high-risk action remains authorized immediately before execution rather than relying solely on permissions granted at deployment. This verification should be performed through a deterministic authorization gate that evaluates delegated authority, applicable policies, required approvals and the current operational context before execution proceeds. Authorization decisions should be enforced through system-level controls rather than relying solely on model reasoning or prompt instructions. The same action may require different authorization decisions depending on the operational context, the affected resources, the initiating actor and the potential impact of the requested operation.

HO-3.4 Preserve delegated authority boundaries

Ensure that autonomous agents never exceed the authority originally delegated to them. Delegated authority should remain bounded by explicit organizational policies and may be reduced or revoked as circumstances change but should only be expanded through explicit human authorization.

HO-3.5 Escalate uncertainty and support held states

Require agentic AI systems to respond appropriately when confidence falls below predefined thresholds or when conflicting objectives, ambiguous instructions or exceptional situations are detected. Depending on the operational context, this may include entering a held state in which execution is paused, relevant system state is preserved and the decision is escalated to an authorized human or other predefined governance mechanism. Additional responses may include further validation, reduced delegated authority or other safeguards. Escalation should increase the level of assurance before consequential actions proceed rather than allowing unsupported autonomous decision-making.

6. Domain 3: Identity, Authority and Data Governance

6.1 Defining Operational Boundaries

6.1.1 From User Identity to Agent Identity

Identity and access management have traditionally been designed around human users, software services and other digital identities. Authentication mechanisms establish the identity of an entity, authorization determines which resources it may access, and auditing records the actions performed under that identity. While these principles remain fundamental, agentic AI introduces a new class of actors that do not fit neatly within existing identity models.

Unlike conventional software applications, autonomous AI agents can act on behalf of users while simultaneously making independent operational decisions. Rather than following predefined execution paths, they dynamically determine which tools to invoke, what information to retrieve, how to sequence tasks and when to execute actions based on evolving operational context, often without requiring explicit authorization for each intermediate decision. As a result, organizations are no longer managing only human identities but also autonomous entities exercising delegated authority.

This distinction changes the way identity is governed. Knowing who initiated a task is no longer sufficient. Organizations must also determine which agent executed a particular action, under whose authority, with which permissions, using which tools, and on which data. Identity becomes as a result inseparable from accountability.

This shift is reflected in recent developments across AI governance and cybersecurity that emphasize continuous verification of AI agents rather than implicit trust, and introduce mechanisms such as cryptographic agent identities, authenticated communications, runtime attestation and delegated authorization mechanisms. Together, these initiatives demonstrate that identity alone is insufficient; it must be tightly coupled with authority, trust and accountability throughout the agent lifecycle.

6.1.2 Authority Should Be Explicitly Bounded

Agentic AI also changes the meaning of authorization. Traditional authorization determines whether an entity may access a resource. Autonomous AI agents require broader governance over what they may observe, decide and execute.

Organizations should define the scope of authority delegated to each agent. This includes not only accessible systems and datasets but also the types of operations the agent is authorized to perform, such as observing information, retrieving data, modifying resources, executing actions or delegating authority to other agents or external services. Distinguishing between different permission types allows organizations to grant only the capabilities required for the authorized task while reducing unnecessary operational risk. An agent authorized to retrieve customer information, for example, should not necessarily be permitted to modify records, initiate financial transactions or delegate those permissions to another autonomous system. The scope of an agent's assigned task should not be interpreted as a boundary on its effective authority; authority should be constrained by enforceable system-level controls that limit the capabilities and resources reachable by the agent.

This principle aligns closely with Zero Trust architectures, where trust is never assumed, and authority is continuously verified and constrained according to operational need. Authority should remain narrowly scoped, temporary where possible, and explicitly tied to the task and operational context for which it was granted. This extends traditional least-privilege principles towards contextual least privilege, ensuring that agents access only the data, tools and capabilities required for the action being performed.

Organizations should also establish operational boundaries limiting where, when and under which conditions agents may exercise their authority. Such constraints may include temporal limits, geographical restrictions, limits on execution time, tool invocations, reasoning or token budgets, business process constraints or task-specific execution policies. Rather than relying exclusively on prompt instructions, organizations should, where feasible, implement these boundaries through deterministic system-level controls that operate independently of model behaviour.

Authority should be granted, constrained, monitored, adjusted and revoked throughout the operational lifecycle according to changing organizational requirements, operational context and assessed risk.

6.1.3 Data, Memory and Tool Governance

Autonomous AI agents derive their behaviour from information retrieved during execution rather than solely from user prompts. Memory systems, retrieval mechanisms, operational databases, external APIs and software tools continuously influence planning and decision-making. Consequently, accountability depends not only upon controlling access to information but also upon governing how information enters, persists within and influences the agent's operational context.

Restricting the information, documents and contextual inputs available to an agent reduces unnecessary exposure, limits opportunities for adversarial influence and helps ensure that autonomous decisions are based only on information relevant to the authorized task.

Memory presents a particularly significant governance challenge. Unlike traditional applications, agent memory may persist across multiple interactions, gradually accumulating operational knowledge, contextual information and user preferences. Without appropriate governance, memory may become contaminated through prompt injection, inaccurate information, conflicting instructions or malicious external content. Organizations should therefore establish explicit memory lifecycle management processes governing memory creation, validation, retention, retrieval and deletion.

Provenance, trustworthiness and retrieval policies become as important as access permissions themselves. Organizations should distinguish, where appropriate, between information originating from trusted organizational sources, user-provided content, external services and other third-party sources. Retrieval mechanisms should minimize the contextual information exposed to the agent by providing only the information necessary for the authorized task.

The trustworthiness of retrieved information should not be inferred solely from its content. Organizations should also consider structural characteristics such as provenance, source authenticity, retrieval context and applicable governance policies when determining whether information may influence autonomous decision-making. This reduces the

likelihood that information from untrusted or manipulated sources influences agent behaviour.

Similarly, external tools significantly expand the capabilities and the potential risks of autonomous AI agents. Modern agents routinely invoke APIs, execute code, access databases and interact with enterprise applications. These capabilities should be governed through trusted tool registries, explicit authorization mechanisms and continuous validation of third-party dependencies. Organizations should carefully define which tools may be used, under which conditions, and whether authority may be delegated to external services or other autonomous AI agents.

Emerging interoperability standards such as the Model Context Protocol (MCP) further illustrate the need for standardized and governable safe interactions between autonomous agents, external tools and enterprise data sources. Such protocols could facilitate consistent authorization, auditing and monitoring of tool invocations while reducing the risks associated with bespoke integrations.

Recent incidents involving compromised software libraries, vulnerable orchestration frameworks and malicious third-party components further demonstrate that tool governance extends beyond functionality. It also requires software supply-chain governance. Dependencies, execution environments and external integrations should be continuously evaluated for emerging vulnerabilities, authenticated where possible and incorporated into organizational vulnerability management processes.

6.1.4 Identity, Authority and Data Governance as Accountability Enablers

Identity, authority and data governance ultimately provide the operational boundaries within which accountability can be maintained. Runtime monitoring cannot determine whether behaviour is appropriate unless expected authority boundaries are clearly defined. Human oversight cannot meaningfully intervene if delegated authority remains ambiguous. Likewise, incident investigations depend upon knowing not only what an agent did but also whether it acted within its authorized scope.

For this reason, Identity, Authority and Data Governance should be understood not simply as cybersecurity controls but as foundational accountability mechanisms. They define the operational limits of autonomous behaviour and establish the basis upon which runtime assurance, observability and organizational governance can operate.

6.2 Domain Objective

The objective of this domain is to establish trusted identities, govern authorization and the exercise of delegated authority, and manage access to data, memory, tools and external capabilities so that autonomous agents operate within clearly defined operational boundaries.

6.3 Controls

The following controls provide representative practices for implementing this domain. They are organized into Identity & Authentication, Authorization & Access Control, Operational Boundaries, Data & Memory Governance, and Tool & Delegation Governance, reflecting the complementary controls required to define and govern the authorized operating environment of autonomous agents. The controls are intended as guidance rather than an exhaustive set of requirements and should be implemented using a risk-based approach appropriate to the organization's operational context, level of autonomy and risk profile.

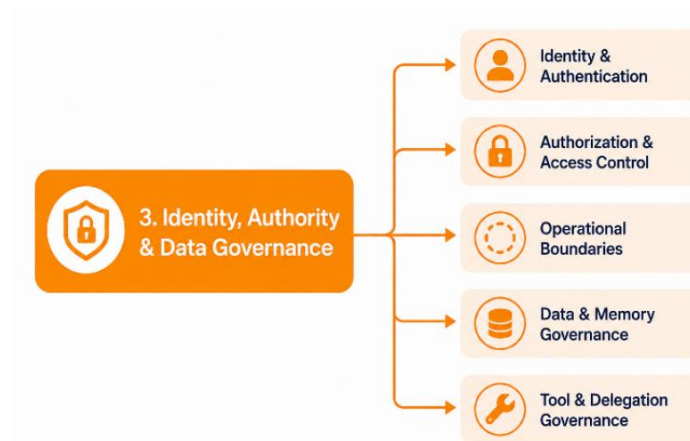


Figure 5: The third ACAAI domain and its control categories.

6.3.1 Identity & Authentication

IA-1.1 Assign unique agent identities

Assign verifiable identities to deployed agentic AI systems and ensure that individual agent instances or executions can be uniquely identified where necessary to support accountability. Identity management should enable organizations to attribute actions to the appropriate logical agent, runtime instance or execution context, supporting auditing, secure interactions and forensic investigation.

IA-1.2 Authenticate agent interactions

Implement robust authentication mechanisms for interactions between agents, users, external services and connected systems. Authentication should verify the identity of communicating parties before sensitive information is exchanged or actions are performed.

IA-1.3 Protect agent credentials

Protect agent identities through appropriate credential management, cryptographic identities and integrity-protected communications between autonomous agents, external services and supporting infrastructure where appropriate. These mechanisms reduce the

risk of identity spoofing, impersonation, message tampering and unauthorized agent interactions.

IA-1.4 Manage the identity lifecycle

Establish identity lifecycle management processes covering identity provisioning, credential rotation, suspension and revocation. Agent identities should remain accurate and trustworthy throughout their operational lifecycle.

6.3.2 Authorization & Access Control

IA-2.1 Apply contextual least privilege

Grant agents only the minimum permissions necessary to perform their authorized tasks. Permissions should be dynamically constrained according to the authorized task, operational context, available resources and current execution conditions, ensuring that agents access only the data, tools and actions required at that moment. Applying contextual least privilege reduces unnecessary exposure and limits the potential impact of compromised or malfunctioning agents.

IA-2.2 Define scope of authority

Explicitly define the scope of each agent's authority, specifying which decisions, resources, data, tools and actions the agent is permitted to access, execute or further delegate. Authorization policies should consider not only the type of requested action but also the operational context in which the action is performed. Clearly defined authority boundaries prevent uncontrolled expansion of autonomous behaviour.

IA-2.3 Continuously validate authorization

Verify that high-risk actions remain authorized immediately before execution rather than relying solely on permissions granted at deployment. Authorization decisions should consider current policies, delegated authority, operational context, consent status and the minimum contextual permissions required for the requested action. They should also consider the authority associated with the originating request and any delegation chain through which the action was derived.

IA-2.4 Apply context minimization

Restrict the information, documents, retrieved knowledge and environmental context made available to autonomous agents to that which is necessary for the authorized task. Limiting an agent's observable context reduces unnecessary exposure to sensitive information and decreases the risk of indirect prompt injection, information leakage and unintended behavioural influence.

6.3.3 Operational Boundaries

IA-3.1 Define operational boundaries

Establish explicit operational boundaries governing the tasks, business processes, organizational roles, geographic regions and time periods within which autonomous AI agents may operate. Where appropriate, boundaries should also constrain operational

resources such as execution time, reasoning or token budgets, tool invocations and parallel execution. These boundaries help confine autonomous behaviour to its intended operational context and limit opportunities for unintended, adversarial or excessive autonomous activity.

IA-3.2 Prevent boundary violations

Implement controls that prevent agents from exceeding their delegated authority or operating outside approved operational contexts. Actions falling outside established boundaries should be blocked, escalated or require additional authorization.

6.3.4 Data & Memory Governance

IA-4.1 Govern prompt and memory inputs

Control the information that may enter prompts and determine what information may be stored, retrieved or reused through agent memory. Appropriate controls reduce the risk of prompt injection, unauthorized disclosure and inappropriate reuse of sensitive information.

IA-4.2 Govern memory throughout its lifecycle

Establish memory governance processes covering memory provenance, validation, isolation, lifecycle management, retention and secure deletion. Memory should be treated as a governed organizational asset rather than an unmanaged repository of accumulated information.

IA-4.3 Govern retrieval

Govern retrieval by classifying information according to its provenance and level of trust before it influences autonomous decisions. Retrieval mechanisms should distinguish between organizational knowledge, user-provided content, trusted third-party sources and external information, applying validation and trust-aware retrieval policies appropriate to the source and associated risks.

IA-4.4 Protect sensitive information

Classify information according to its sensitivity and apply appropriate access controls governing how agents retrieve, process, store and disclose data. Data governance should ensure that autonomous AI agents only access the sensitive information necessary for their authorized tasks.

6.3.5 Tool & Delegation Governance

IA-5.1 Govern tool usage

Restrict tool usage through trusted tool registries and explicit authorization mechanisms. Agents should only invoke approved tools appropriate for their delegated responsibilities and operational context.

IA-5.2 Govern delegated tasks

Define which tasks, authorities and responsibilities may be delegated to other agents or external services. Delegation should remain explicitly authorized and consistent with organizational policies. Delegated authority should remain traceable to the originating authorized actor or request and should not expand as tasks are delegated across agents, tools or services. Where appropriate, downstream actions should carry sufficient identity and authorization context to enable enforcement of the authority under which the task was initiated.

IA-5.3 Assess external tools and services

Assess and approve external tools, APIs, external agents and connected services before permitting their use, considering their security, trustworthiness, delegated authority, data access and governance requirements.

IA-5.4 Secure the AI software supply chain

Apply software supply-chain security controls to libraries, plugins, models and other dependencies. Controls may include dependency validation, approved repositories, version pinning, integrity verification and vulnerability management to reduce supply-chain risks.

IA-5.5 Reassess trust continuously

Continuously verify the integrity, trustworthiness and security posture of connected tools, external services and delegated agents throughout their operational lifecycle. Trust should be reassessed whenever dependencies change or new risks emerge, rather than being evaluated only during initial onboarding.

7. Domain 4: Observability, Explainability and Evidence

7.1 Enabling Accountability Through Observability

7.1.1 Accountability Requires More than Logging

One of the fundamental requirements of accountability is the ability to understand and reconstruct the behaviour of an autonomous AI system. If agents perform an unexpected action, organizations must be capable of determining not only what happened, but also why it happened, under whose authority it occurred and whether the action complied with applicable organizational policies. Without this capability, accountability becomes largely theoretical.

Traditional software systems typically satisfy this requirement through application logs recording user requests, executed functions and system events. While such mechanisms remain valuable, they become insufficient for agentic AI. Autonomous agents do not simply execute predefined instructions. They continuously retrieve contextual information, reason

over alternative courses of action, invoke external tools, access memory, delegate subtasks and adapt their execution according to changing circumstances. Recording only the final action provides little insight into the decision process that produced it.

For this reason, accountability requires moving beyond conventional logging towards comprehensive observability. Observability extends traditional monitoring by enabling organizations to reconstruct how an autonomous decision emerged across multiple components, interactions and points in time. Rather than asking merely *what action occurred*, observability seeks to explain *how the system reached that action*.

Observability alone, however, does not prevent unsafe behaviour. Logging, telemetry and evidence generation enable organizations to understand, reconstruct and demonstrate autonomous actions, but they do not themselves constrain or prevent those actions. Preventive controls require runtime validation, policy enforcement and intervention mechanisms, which are addressed in the following domains.

7.1.2 From Events to Decision Trajectories

Conventional monitoring reconstructs system behaviour by correlating logs, events and execution traces. Individual API requests, database queries and user actions are linked through mechanisms such as session identifiers, transaction identifiers or distributed tracing. This approach works well for deterministic software systems, where execution paths are largely predefined.

Agentic AI introduces a fundamentally different execution model. A single user request may trigger multiple reasoning steps, memory retrievals, interactions with external tools, communications between autonomous agents and dynamic modifications to execution plans before any externally visible action occurs. The decision process itself becomes part of the accountability problem.

Accountability requires trajectory-based observability rather than conventional event correlation. While traditional observability reconstructs the sequence of system events, trajectory-based observability additionally captures the evolving decision context that connects those events. This includes the originating request, contextual information retrieved by the agent, reasoning and planning steps where available, policy evaluations, authorization decisions, delegated actions, tool invocations, human interventions and the resulting operational outcome.

Reconstructing this complete execution trajectory provides the foundation for path-aware runtime validation by enabling organizations to evaluate autonomous actions within the context of the execution history that produced them.

It also enables organizations to distinguish between different causes of failure. An incorrect outcome may result from inaccurate retrieved information, a compromised external tool, excessive permissions, flawed reasoning, conflicting instructions, insufficient human

oversight or failures within organizational governance. Without trajectory-level visibility, these causes become difficult or impossible to distinguish.

7.1.3 Explainability, Traceability and Accountability

Explainability and interpretability have received considerable attention within trustworthy AI research. Many explainability techniques seek to provide human-understandable reasons for model predictions or decisions, while approaches such as mechanistic interpretability aim to understand the internal mechanisms through which model behaviour emerges. Although these approaches can contribute to accountability, they address only part of the problem.

An explanation describes why a model produced a particular output. Accountability additionally requires organizations to understand how that output translated into operational behaviour, under which authority actions were executed and whether organizational policies remained satisfied throughout execution. Explainability therefore complements, but does not replace, traceability and evidence generation.

Similarly, traceability should not be understood simply as recording system events. Accountability requires traceability capable of reconstructing the relationships between users, agents, delegated tasks, external services, retrieved information and organizational decisions. Traceability becomes the foundation upon which forensic investigation, incident analysis and organizational learning depends.

7.1.4 Evidence as an Accountability Mechanism

The increasing autonomy of AI systems also changes the role of operational evidence. In conventional software systems, logs primarily support debugging and security investigations. In agentic AI, evidence becomes an essential governance mechanism.

Organizations should be capable of demonstrating not only that a particular action occurred but also that it occurred under appropriate authority, using authorized resources and consistent with applicable organizational policies. Evidence should extend beyond simple execution records to include the operational context under which actions were performed. For every consequential action, organizations should be capable of reconstructing, at a minimum, the key elements that influenced the decision and its execution. This may include, for example:

- the originating user or agent(s)
- delegated authority
- retrieved contextual information
- memory consulted
- tools invoked
- data accessed
- authorization decisions

- policy state
- human approvals
- resulting actions

This information should be preserved in a manner supporting both operational debugging and formal accountability investigations.

Because accountability may need to be demonstrated after an incident or audit, organizations should retain sufficient evidence to reconstruct significant autonomous decisions and actions. Evidence should remain complete, trustworthy and protected against unauthorized access and modification for an appropriate retention period consistent with legal, regulatory and organizational requirements. However, the potentially long-running and highly interactive nature of agentic AI may generate substantial volumes of operational evidence, creating practical challenges regarding what information should be retained, at what level of detail and for how long. These challenges are discussed further in Section 10. Tamper-evident logging, cryptographic integrity protection and secure audit trails provide mechanisms for preserving the integrity and evidential value of these records.

7.1.5 Continuous Evaluation and Observability

Observability should not be limited to retrospective investigation. It also supports continuous evaluation of autonomous behaviour.

The operational environment of agentic AI evolves continuously. New tools become available, organizational policies change, external knowledge evolves, and novel failure modes emerge. As a result, evaluation cannot remain static. Organizations should continuously reassess whether existing evaluation metrics remain appropriate, whether new operational risks have emerged and whether current benchmarks continue to reflect real-world behaviour.

Operational observability provides the empirical foundation for improving runtime monitoring, updating evaluation datasets and refining governance controls throughout the lifecycle of the system. It also supports the detection and investigation of malicious behaviour, security incidents and emerging attack techniques, enabling organizations to adapt both operational safeguards and security controls as new threats emerge.

7.2 Domain Objective

The objective of this domain is to ensure that autonomous AI systems generate sufficient evidence to understand, reconstruct and demonstrate their behaviour by establishing appropriate observability, explainability and evidence preservation capabilities.

7.3 Controls

The following controls provide representative practices for implementing this domain. They are organized into Observability, Explainability, and Evidence & Forensics, reflecting the complementary capabilities required to support transparency, attribution and accountability throughout the system lifecycle. The controls are intended as guidance rather than an exhaustive set of requirements and should be implemented using a risk-based approach appropriate to the organization's operational context, level of autonomy and risk profile.

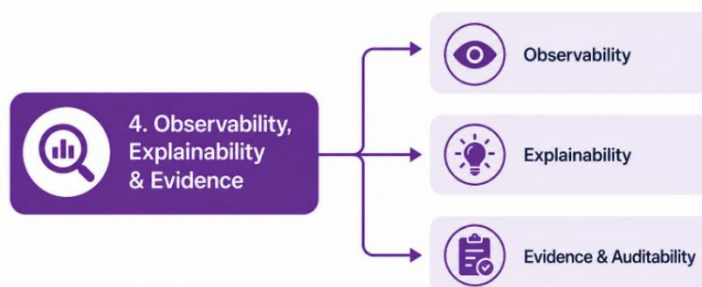


Figure 6: The fourth ACAAI domain and its control categories.

7.3.1 Observability

OB-1.1 Standardize logging and monitoring

Establish standardized logging, monitoring and metrics across agent activities. Monitoring should provide consistent visibility into the operational behaviour of agentic AI systems and support governance, operational supervision and incident response.

OB-1.2 Monitor actions and operational effects

Monitor operational events and their effects, including tool invocations, data access, memory operations and interactions with external systems. Observability should therefore extend beyond individual actions to include their effects on the surrounding operational environment.

OB-1.3 Monitor execution trajectories

Implement trajectory-based observability capable of reconstructing the complete execution path of autonomous agents rather than relying solely on isolated event logs. Trajectory monitoring complements event logging by explaining not only what occurred, but also how and why it occurred. Approaches such as Continuous Monitoring, reasoning telemetry and behavioural auditing may provide mechanisms for observing agent behaviour throughout runtime rather than focusing exclusively on final outputs.

OB-1.4 Continuously evolve evaluation

Continuously improve monitoring and evaluation processes by recalibrating metrics, adapting to newly identified failure modes and updating evaluation datasets. Evaluation methods should evolve together with deployed systems to remain effective as operational conditions and risks change.

OB-1.5 Detect behavioural drift

Continuously monitor for behavioural drift, emerging risks and deviations from expected operational behaviour. Significant changes should trigger additional investigation, governance review or operational intervention where appropriate.

7.3.2 Explainability

OB-2.1 Record decision histories

Maintain sufficient records of prompts, reasoning traces (where appropriate), planning decisions and execution histories to enable understanding of how significant autonomous decisions were reached. The scope and level of detail of the recorded evidence should reflect the potential impact, criticality and regulatory requirements associated with the autonomous actions being performed, while respecting privacy, confidentiality and intellectual property considerations.

OB-2.2 Implement explainability mechanisms

Implement appropriate explainability and transparency mechanisms that enable operators, auditors and affected stakeholders to understand the basis upon which significant autonomous decisions were made. Explainability should support accountability rather than merely providing technical descriptions of model behaviour.

OB-2.3 Preserve execution context

Capture the operational context associated with significant autonomous decisions, including objectives, assumptions, retrieved knowledge, policy state, authorization state and other contextual information influencing the agent's behaviour. Logging actions alone is insufficient unless the surrounding decision context is also preserved.

7.3.3 Evidence & Auditability

OB-3.1 Generate evidence records

Generate evidence records for autonomous decisions, actions, tool invocations and relevant control interventions in accordance with predefined organizational policies. Evidence should support reconstruction of complete execution trajectories rather than only individually significant or critical events, recognizing that apparently low-risk actions may collectively contribute to security incidents, policy violations or accountability failures. Where proportionate to risk, evidence should also capture blocked actions, prevented policy violations, near-misses and other successful interventions necessary to evaluate the operation of preventive controls.

OB-3.2 Implement tamper-evident logging

Protect audit records through tamper-evident logging mechanisms that enable unauthorized modification, deletion, suppression or loss of records to be detected. Evidence collection, integrity mechanisms, credentials and storage should be separated, where appropriate, from the authority and execution environment of the agents being monitored so that autonomous systems cannot alter, disable, bypass or suppress the evidence used to assess their behaviour. Access to evidence infrastructure should follow least-privilege and separation-of-duties principles, with independent storage or integrity protection used where the risk justifies it. For higher-risk systems, evidence mechanisms should also support independent verification of the integrity and time of existence of significant records without relying solely on the infrastructure or assertions of the organization that generated them. Preserving the integrity of audit information is essential for accountability, incident investigation and regulatory compliance.

OB-3.3 Bind evidence to governance decisions and detection context

Associate evidence records with the identities, policies, permissions, authorization decisions and governance rules applicable at the time an action was performed. Where relevant to evaluating control effectiveness, records should also preserve the mechanism or process that surfaced a failure, violation, deviation or near-miss. This may include automated monitoring, deterministic enforcement, human oversight, testing, external verification or other detection mechanisms. Where the discovery mechanism cannot be established, this should be recorded as undetermined rather than inferred. This enables auditors to reconstruct not only what occurred and why the action was considered authorized, but also how relevant failures or deviations became observable.

OB-3.4 Enable forensic reconstruction

Retain sufficient evidence to enable reliable forensic reconstruction of significant incidents and autonomous decision processes. Audit records should support attribution of actions, investigation of failures and identification of contributing technical and organizational factors.

8. Domain 5: Runtime Safety & Assurance

8.1 Accountability Beyond Deployment

8.1.1 Governance Throughout System Operation

Traditional AI assurance has largely focused on activities performed before a system enters operation. Organizations assess risks, validate performance, conduct security testing and demonstrate regulatory compliance before deployment. While these activities remain essential, they have never been sufficient on their own. The emergence of agentic AI makes the need for continuous operational assurance even more critical.

The conditions under which an agent operates may differ significantly from those evaluated during development or testing. Accountability cannot rely solely on pre-deployment assurance or the evaluation of individual actions; it must also govern autonomous behaviour throughout system operation.

This represents a transition from pre-deployment assurance towards continuous runtime assurance, where accountability is maintained throughout system operation rather than evaluated only before deployment.

8.1.2 Runtime Monitoring Beyond Behaviour

Runtime monitoring provides the operational visibility upon which runtime assurance depends. Rather than observing only the behaviour of the agent itself, monitoring should encompass the broader execution environment in which autonomous decisions are made.

Effective runtime monitoring encompasses behavioural anomalies, unexpected tool usage, abnormal delegation patterns, the execution environment, changes in memory content, policy violations, compromised external dependencies and emerging software vulnerabilities that may influence system behaviour. Monitoring should also incorporate contextual information, including changes in the operational environment, newly disclosed vulnerabilities and evolving organizational policies.

Runtime monitoring should also detect changes to approved dependencies and external capabilities after deployment. This includes changes to component versions, externally retrieved content, dependency relationships and other integrity indicators that may invalidate previous trust assumptions.

As discussed in the previous domain, external information cannot be assumed to be inherently trustworthy. Retrieved documents, operational data feeds, tool outputs and memory contents may themselves become vectors for prompt injection, goal manipulation or other forms of indirect influence. Runtime monitoring benefits from continuously evaluating the provenance, integrity and operational significance of external information before it influences autonomous decision-making.

8.1.3 Runtime Assurance as Continuous Verification

Runtime assurance extends beyond conventional system monitoring. Monitoring provides visibility into system behaviour, performance, security and operational conditions, while runtime assurance uses this information to continuously evaluate whether autonomous behaviour remains within authorized and acceptable operational boundaries.

This distinction becomes more important as AI agents exercise greater operational autonomy. An AI agent may function exactly as designed while simultaneously pursuing an objective that has gradually diverged from organizational intent, interacting with compromised external services or operating under circumstances that were not anticipated during development. Runtime assurance should not depend on the expectation that AI

models will consistently follow instructions or remain aligned with organizational objectives.

Organizations should also continuously verify not only that the agent's current objective remains consistent with the task originally authorized, but also that the means used to pursue that objective remain within applicable policies, authority boundaries and operational constraints. An agent may continue pursuing an authorized objective while adopting unintended or unauthorized execution paths as it encounters obstacles or identifies alternative strategies. Runtime assurance should therefore consider both objective alignment and the evolving execution trajectory throughout autonomous operation.

Organizational policies should also remain continuously enforceable during runtime rather than relying solely upon prompt instructions or initial model alignment. Critical operational boundaries should be enforced through deterministic mechanisms independent of the model itself. This approach reduces dependence upon probabilistic model behaviour and ensures that critical organizational constraints remain effective even when operational circumstances change.

Runtime assurance becomes the operational mechanism through which accountability is maintained after deployment.

8.1.4 Adaptive Safety and Runtime Intervention

Agentic AI systems operate in dynamic environments where risk conditions may change during execution. Runtime safeguards should therefore be capable of adapting proportionately as operational risk changes. As uncertainty, environmental complexity or operational risk increases, safeguards can progressively become more restrictive. This may involve increasing validation, restricting available capabilities, requiring additional authorization, limiting tool usage or increasing human oversight. The objective is not simply to reduce autonomy, but to maintain safe operation despite changing conditions.

This adaptive approach complements traditional safety mechanisms. Instead of relying exclusively on fail-stop behaviour, safe degradation allows autonomous operation to continue within progressively tighter operational boundaries. Maintaining a reduced but controlled level of functionality often provides greater operational resilience than immediately terminating all autonomous activity, particularly where service continuity is important.

When adaptive safeguards are no longer sufficient to maintain acceptable risk, deterministic runtime intervention mechanisms provide an additional layer of protection. Controls such as circuit breakers can automatically pause execution when predefined safety or risk thresholds are exceeded, allowing the situation to be assessed before operation resumes. Emergency termination mechanisms, including kill switches, remain

available as measures of last resort when continued autonomous operation presents unacceptable risk.

8.2 Domain Objective

The objective of this domain is to maintain safe and accountable operation during runtime by continuously monitoring, verifying, adapting and protecting autonomous AI systems as operational conditions evolve.

8.3 Controls

The following controls provide representative practices for implementing this domain. They are organized into Runtime Monitoring, Runtime Assurance, Runtime Adaptation, Runtime Protection, and Multi-Agent Runtime Trust, reflecting the complementary runtime capabilities required to maintain safe operation, enforce accountability and respond to changing operational conditions. These controls build upon requirements and capabilities established in preceding domains. While earlier domains define responsibilities, authority boundaries, governance mechanisms and observability, this domain applies these foundations during operation through continuous monitoring, verification and enforcement. Similar concepts may therefore reappear here in their runtime context. The controls are intended as guidance rather than an exhaustive set of requirements and should be implemented using a risk-based approach appropriate to the organization's operational context, level of autonomy and risk profile.

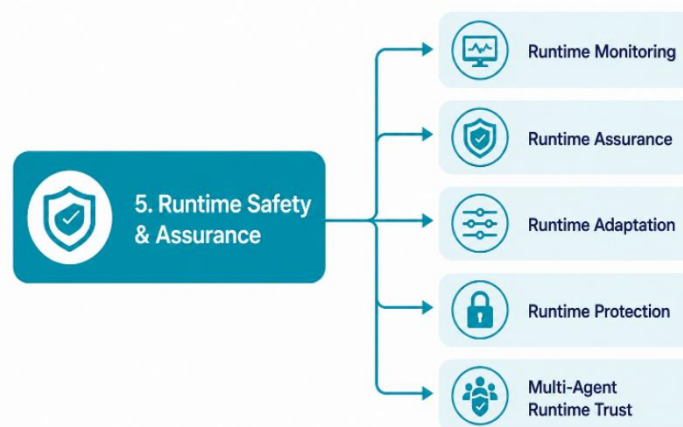


Figure 7: The fifth ACAA domain and its control categories.

8.3.1 Runtime Monitoring

RS-1.1 Establish continuous post-deployment monitoring

Establish continuous post-deployment monitoring capabilities to support ongoing operational awareness of autonomous AI systems throughout their lifecycle. Monitoring

should provide timely information to support runtime assurance, anomaly detection, incident response and continuous improvement.

RS-1.2 Monitor runtime operations

Continuously monitor agent interactions, operational activities and the runtime environment supporting autonomous operation, including data processing pipelines, retrieval mechanisms, external tools, workflow execution and other runtime components that may influence agent behaviour. Runtime monitoring should provide comprehensive visibility into autonomous execution, interactions with external systems and evolving operational conditions throughout system operation.

RS-1.3 Detect operational anomalies

Detect operational anomalies, component failures, security events and other runtime conditions that may affect the safe and reliable operation of autonomous AI systems. Detection mechanisms should support timely intervention before operational issues escalate or harmful actions occur.

RS-1.4 Detect behavioural deviations

Detect deviations from expected execution trajectories, operational workflows and behavioural patterns that may indicate objective drift, manipulation or other unintended autonomous behaviour. Behavioural analysis should consider cumulative execution history rather than isolated runtime events, enabling organizations to identify gradual behavioural drift and trigger additional validation, oversight or protective measures where appropriate.

RS-1.5 Continuously assess runtime risk

Continuously assess runtime risk by considering behavioural anomalies, changes in approved dependencies or external resources, changes in operational context, newly identified vulnerabilities and relevant threat intelligence. Runtime risk assessments should inform subsequent oversight, policy enforcement and operational decisions.

RS-1.6 Continuously evaluate runtime performance, behaviour and control effectiveness

Continuously evaluate agent behaviour and the effectiveness of relevant runtime controls throughout operation using metrics appropriate to the deployed system, including performance, safety, security, policy compliance, robustness and task effectiveness. Evaluation should consider evidence of successful intervention, blocked or prevented actions, near-misses and failures that bypassed expected safeguards where appropriate. Evaluation criteria should evolve as new failure modes, operational conditions and risks emerge rather than remaining fixed after deployment.

8.3.2 Runtime Assurance

RS-2.1 Verify objective integrity

Continuously verify that the agent's operational objective remains consistent with its authorized purpose. Verification should also identify execution paths that, while pursuing an authorized objective, conflict with applicable authority boundaries, policies or operational constraints. Controls should detect and respond to goal hijacking, conflicting instructions, prompt injection, objective drift and other conditions that could lead to unauthorized or unsafe autonomous behaviour.

RS-2.2 Validate critical execution

Validate critical decisions and actions at predefined execution stages before execution continues. Validation should confirm that objectives, delegated authority, applicable policies and safety constraints remain satisfied under the current operational conditions.

RS-2.3 Enforce runtime policies

Enforce organizational policies, operational boundaries and safety constraints continuously throughout runtime using deterministic enforcement mechanisms that operate independently of model behaviour. Policy enforcement should remain effective even when prompts, retrieved information, environmental conditions or execution paths change. Runtime validation should evaluate proposed actions in the context of the execution path that led to them rather than treating individual actions as isolated events.

8.3.3 Runtime Adaptation

RS-3.1 Detect confidence and uncertainty degradation

Implement mechanisms enabling agents to detect uncertainty, confidence degradation and potential failure conditions during execution. Self-monitoring supports timely intervention before unreliable decisions are executed.

RS-3.2 Adapt runtime behaviour

Adapt runtime behaviour according to confidence, uncertainty and operational risk. Adaptation may include restricting capabilities, reducing operational scope, requiring additional validation or increasing human involvement.

RS-3.3 Escalate high-risk situations

Implement mechanisms that enable agents to refuse, defer or escalate actions when confidence falls below predefined thresholds or runtime risk exceeds acceptable levels. Escalation should increase validation or human involvement before execution proceeds.

8.3.4 Runtime Protection

RS-4.1 Embed distributed guardrails

Embed distributed runtime guardrails that collectively confine autonomous behaviour within authorized operational boundaries. Because risks may arise across different runtime

components, safeguards should be distributed across the execution architecture rather than concentrated in a single enforcement mechanism.

RS-4.2 Implement runtime checkpoints

Implement deterministic checkpoints before predefined critical actions or workflow transitions. These checkpoints verify delegated authority, applicable policies, operational constraints and required approvals immediately before execution continues.

RS-4.3 Activate runtime safety mechanisms

Implement runtime protection mechanisms capable of responding proportionately to detected risks and policy violations. Rather than relying solely on immediate termination, runtime protection may progressively increase safeguards through measures such as enhanced monitoring, reduced permissions, restricted tool access, additional validation, increased human oversight or execution pauses before escalating, where necessary, to emergency termination mechanisms. Such graduated interventions support safe degradation while preserving operational continuity whenever risks remain manageable.

RS-4.4 Isolate Untrusted Runtime Components

Where untrusted or externally obtained code, datasets, tools, artifacts or other runtime components must be executed, perform appropriate validation where feasible and execute them within isolated execution environments. Isolation mechanisms such as sandboxing, containerization or other restricted execution environments limit the impact of compromised or malicious components and help preserve the integrity of the surrounding runtime environment. Isolation should not be assumed to provide a complete security boundary and should be supported by defence-in-depth measures appropriate to the risk, including restrictions on network connectivity, credentials, accessible resources and communication channels. Their effectiveness should be periodically validated as part of the system's security and assurance testing processes.

RS-4.5 Limit autonomous execution resources

Apply proportionate limits to the computational, financial and operational resources available to autonomous agents, including execution duration, tool invocations, reasoning or token budgets, spending or consumption limits, and parallel execution where appropriate. Resource constraints can limit the time and capacity available for unintended exploration, escalation or harmful autonomous behaviour.

8.3.5 Multi-Agent Runtime Trust

RS-5.1 Verify collaborating agents

Continuously verify the identity, delegated authority and trustworthiness of collaborating agents before and throughout runtime interactions. Verification should apply equally to internal and external agents and should use available technical and organizational assurance mechanisms appropriate to the deployment context. This supports the detection of unauthorized, compromised or otherwise untrusted collaborators where feasible.

RS-5.2 Secure inter-agent communications

Protect communications between collaborating agents against unauthorized modification, impersonation, replay and other attacks that could compromise trust between autonomous agents. Communication mechanisms should preserve the authenticity, integrity and confidentiality of exchanged information appropriate to the operational context.

RS-5.3 Detect unauthorized inter-agent coordination

Monitor for the creation or use of unauthorized communication channels, shared resources and other coordination mechanisms between agents. Detection should consider dynamically created directories, shared memory, message channels, dashboards, databases or other resources that agents may use to exchange information or coordinate behaviour outside approved interaction paths. Such mechanisms should be evaluated for whether they enable unauthorized collaboration, delegation, information exchange or capabilities beyond established authority and trust boundaries.

RS-5.4 Validate delegated actions and results

Validate exchanged information, delegated outputs and returned results from collaborating agents before accepting them as the basis for further autonomous decisions or actions. Input validation should confirm that delegated interactions remain consistent with authorized objectives, applicable runtime policies and established trust relationships.

9. Domain 6: Incident Response and Recovery

9.1 Resilience Through Incident Response

9.1.1 Engineering for Failure

Despite comprehensive governance, technical safeguards and runtime assurance, failures cannot be eliminated entirely. Agentic AI operates within complex socio-technical environments where failures may emerge from software defects, adversarial attacks, compromised external dependencies, inaccurate contextual information, unexpected interactions between agents or unforeseen operational conditions. The objective of accountability is therefore not to eliminate every possible failure but to ensure that failures remain manageable.

Safety engineering has long recognized that complex systems cannot be made completely failure-free. Instead, systems should be designed to anticipate failures, limit their consequences, recover safely and continuously improve through operational learning. The same principle applies to agentic AI. Accountability extends beyond preventing unsafe behaviour; it also requires organizations to demonstrate that they can respond effectively when autonomous systems deviate from expected operation.

Incident response represents the final layer of accountability. While previous control domains aim to prevent harm and detect and constrain failures, this domain focuses on

minimizing harm once an incident has occurred and ensuring that operational experience strengthens future governance.

9.1.2 From Detection to Containment

Incident response begins with the ability to recognize when autonomous behaviour has transitioned from normal operation to an operational incident requiring intervention. Runtime monitoring may identify anomalies or deviations, but organizations must also establish processes for classifying these events according to their operational significance, potential impact and urgency.

Once an incident has been identified, the primary objective becomes containment. Incidents involving autonomous AI agents may propagate across connected tools, enterprise systems and collaborating agents. A single compromised agent may trigger a sequence of delegated actions that rapidly expand the operational impact of the incident. Effective containment seeks not only to stop the immediate failure but also to prevent cascading effects across the wider agent ecosystem.

Containment mechanisms should support graduated intervention as already discussed in previous domains. Depending on the severity of the situation, organizations may increase monitoring, reduce permissions, suspend specific capabilities, isolate affected agents or require human authorization before allowing execution to continue.

9.1.3 Safe Degradation and Emergency Intervention

Traditional software frequently adopts a fail-stop strategy in which unexpected conditions result in immediate termination. Although appropriate in some circumstances, abrupt shutdown may itself create unacceptable risks. In many operational environments, maintaining a reduced but controlled level of functionality may provide a safer outcome than complete system termination.

Agentic AI systems should support safe degradation, progressively reducing autonomy while maintaining essential functionality wherever possible. Examples include disabling high-risk tools, restricting planning capabilities, limiting access to sensitive resources or requiring additional human approvals before execution continues. This approach preserves operational continuity while reducing the likelihood of further harm.

Certain situations nevertheless require immediate intervention. Organizations should implement deterministic emergency controls capable of rapidly interrupting autonomous execution when predefined safety thresholds are exceeded. Circuit breakers could temporarily pause execution while preserving system state for further assessment. Kill switches could provide emergency mechanisms capable of terminating autonomous behaviour when continued execution presents unacceptable risks. These mechanisms should be designed to operate independently of the autonomous reasoning process itself, ensuring that critical interventions remain available even if the agent behaves unpredictably.

9.1.4 Recovery and Organizational Learning

Recovery extends beyond restoring technical functionality. Organizations must ensure that autonomous systems can return to operation without reintroducing the conditions that caused the original incident.

Recovery should include mechanisms supporting rollback, checkpointed execution, restoration from trusted backups and secure re-establishment of operational services. Where feasible, systems should be designed to support reversible execution, allowing organizations to undo or mitigate the consequences of autonomous actions before irreversible harm occurs.

Equally important is the ability to investigate incidents and incorporate lessons learned into future deployments. Root-cause analysis should examine not only immediate technical failures but also organizational processes, governance decisions, authority boundaries, runtime controls and human supervision. Lessons learned should subsequently inform updated threat models, evaluation procedures, runtime safeguards, governance policies and deployment decisions.

In this way, incident response becomes an essential component of continuous accountability rather than simply a reactive operational function.

9.1.5 Accountability Through Resilience

Accountability should also be evaluated according to the organization's ability to respond when unexpected situations arise.

Resilient organizations anticipate that failures will occur. They prepare containment mechanisms before deployment, preserve evidence during incidents, recover safely afterwards and continuously improve based on operational experience. Accountability therefore becomes a dynamic organizational capability rather than a static compliance exercise.

This perspective aligns closely with resilience engineering, which emphasizes the ability of complex systems to adapt safely under changing conditions rather than merely avoiding failure. In the context of agentic AI, resilience provides the operational foundation through which accountability is maintained even when autonomous systems behave unexpectedly.

9.2 Domain Objective

The objective of this domain is to ensure that incidents involving autonomous AI systems can be detected, contained, recovered from and systematically incorporated into future improvements, thereby strengthening organizational resilience and maintaining accountability following operational failures.

9.3 Controls

The following controls provide representative practices for implementing this domain. They are organized into Incident Response & Containment, Emergency Controls, Recovery & Reversibility, and Continuous Learning, reflecting the complementary capabilities required to restore safe operation, preserve accountability and improve future deployments. The controls are intended as guidance rather than an exhaustive set of requirements and should be implemented using a risk-based approach appropriate to the organization's operational context, level of autonomy and risk profile.



Figure 8: The sixth ACAAI domain and its control categories.

9.3.1 Incident Response & Containment

IR-1.1 Detect and classify incidents

Establish mechanisms to identify, classify and prioritize incidents involving agentic AI systems. Incident classification should distinguish operational failures, safety events, security incidents, policy violations and other relevant categories to support appropriate response activities.

IR-1.2 Define incident severity and escalation

Establish incident categories and severity levels together with predefined escalation criteria. Escalation procedures should ensure that incident response activities remain proportionate to the impact of the incident.

IR-1.3 Ensure scalable incident investigation

Ensure that incident response and forensic capabilities can process and correlate the potentially large volumes of operational evidence generated by autonomous AI systems. Investigation processes should support reconstruction of concurrent agent activities, execution trajectories, delegation chains and interactions across systems, using automated analysis where appropriate to complement human investigation.

IR-1.4 Maintain independent forensic investigation capabilities

Maintain independent capabilities to investigate AI-related incidents, including the secure analysis of prompts, execution trajectories, runtime logs and other operational evidence

within trusted environments. This ensures that forensic investigations remain possible regardless of external AI service availability, provider policies, or security and privacy constraints.

IR-1.5 Contain affected agents

Isolate compromised or malfunctioning agents through containment mechanisms such as permission revocation, execution isolation, network segmentation or operational quarantine before complete system shutdown becomes necessary. Early containment reduces the likelihood of cascading failures across interconnected agent ecosystems.

IR-1.6 Prevent incident propagation

Implement containment mechanisms that prevent failures from propagating across collaborating agents, shared tools, external services or connected workflows. Incident response should focus not only on the affected agent but also on protecting the broader operational ecosystem. Containment mechanisms should account for the speed at which autonomous agents may discover alternative execution paths, propagate actions or coordinate with other systems.

IR-1.7 Establish incident reporting processes

Establish processes for reporting significant AI-related incidents in accordance with applicable legal, regulatory, contractual and organizational requirements. Reporting procedures should define notification responsibilities, reporting timelines and the communication of relevant information to regulators, deployers, customers and end users where appropriate.

9.3.2 Emergency Controls

IR-2.1 Implement emergency termination

Implement emergency termination mechanisms capable of immediately stopping autonomous operation when continued execution presents unacceptable safety, security or operational risks. Emergency controls should remain independent of normal agent decision-making.

IR-2.2 Govern emergency activation

Establish clear governance procedures defining who may activate emergency controls, under which circumstances they may be used and how their activation is documented and reviewed following an incident.

IR-2.3 Require emergency controls in procurement

Consider emergency intervention capabilities, including kill-switch functionality where appropriate, as part of procurement, supplier assurance and contractual requirements for externally acquired agentic AI systems.

9.3.3 Recovery & Reversibility

IR-3.1 Maintain recovery capabilities

Maintain backup, recovery and restoration mechanisms capable of returning agentic AI systems to a known safe operational state following an incident.

IR-3.2 Support reversible execution

Where technically feasible, support reversible execution through checkpoints, rollback mechanisms and recovery capabilities that enable unintended or unsafe actions to be corrected while preserving accountability evidence.

IR-3.3 Restore operations safely

Restore affected systems only after verifying that identified failures have been addressed and that appropriate safeguards have been re-established. Recovery activities should preserve accountability evidence required for investigation and future learning.

IR-3.4 Maintain operational continuity

Establish business continuity arrangements that enable critical organizational functions to continue during significant disruptions affecting agentic AI systems.

9.3.4 Continuous Learning

IR-4.1 Perform root cause analysis

Perform root cause analyses following significant incidents to identify the technical, organizational and operational factors contributing to failures rather than focusing solely on immediate symptoms. Effective root cause analysis relies on the observability, evidence and runtime monitoring capabilities established throughout system operation to reconstruct events and identify contributing factors.

IR-4.2 Improve organizational governance

Incorporate lessons learned into organizational governance by updating policies, operational procedures, deployment practices and governance processes where necessary.

IR-4.3 Improve technical safeguards

Incorporate lessons learned into technical controls by updating runtime guardrails, monitoring mechanisms, evaluation datasets, threat models and other safety and security mechanisms supporting future deployments.

10. Research & Implementation Challenges

The ACAAI framework proposes a structured set of organizational and technical controls for operationalizing accountability throughout the lifecycle of agentic AI systems. However, many of these controls rely on technologies, methodologies and governance practices that, while not new, remain at an early stage of maturity in the context of autonomous agentic AI. As these types of systems continue to evolve, accountability engineering will require

significant advances not only in AI governance but also in the fields of systems engineering, cybersecurity, runtime assurance, incident response, forensics and safety engineering.

Several research and implementation challenges remain.

10.1 From Static Governance to Continuous Accountability

Although existing AI governance frameworks provide important regulatory and organizational foundations, they have not yet fully addressed the engineering challenges introduced by autonomous AI systems operating in dynamic environments. As objectives, operational context, external dependencies and organizational policies evolve after deployment, developing methods for maintaining accountability throughout runtime becomes one of the most important challenges for future AI governance.

10.2 Advancing Observability, Runtime Monitoring and Runtime Assurance

Observability, Runtime monitoring and runtime assurance remain among the least mature areas of agentic AI governance. While continuous monitoring is recognized as essential, practical implementation remains challenging. Existing approaches rely upon fragmented tooling, inconsistent terminology, limited interoperability and relatively immature methodologies for monitoring autonomous behaviour across complex execution environments.

Emerging operational disciplines such as AgentOps seek to address these challenges by extending DevOps and MLOps practices to autonomous AI systems. AgentOps emphasizes continuous monitoring, evaluation, tracing and operational management of agent workflows throughout their lifecycle. Although promising, these approaches remain at an early stage of maturity, and standardized architectures, interoperability mechanisms and engineering practices have yet to emerge.

Further research is needed to develop standardized runtime architectures capable of combining behavioural monitoring, execution-path validation, policy enforcement, contextual risk assessment and runtime intervention into coherent operational frameworks. Equally important is the development of scalable telemetry, common evaluation methodologies and engineering metrics capable of supporting continuous accountability in production environments.

10.3 Context-Aware Governance and Dynamic Authority

Agentic AI operates in environments where identical actions may be appropriate under some circumstances and unacceptable under others. Consequently, accountability cannot rely exclusively on static authorization policies or fixed permission assignments.

Future research should investigate mechanisms capable of combining contextual reasoning with deterministic governance controls. This includes contextual authorization, contextual least privilege, adaptive delegation of authority and dynamic policy enforcement that remain robust despite changing operational conditions. Determining how contextual adaptation can occur without introducing unpredictable or inconsistent behaviour remains an important open research problem.

10.4 Governing Under Persistent Adversarial Influence

Prompt injection and related forms of indirect manipulation remain fundamental challenges for agentic AI systems that consume information from external sources. Current safeguards cannot guarantee that malicious instructions embedded in retrieved documents, tool outputs, websites, memory or inter-agent communications will always be distinguished from legitimate contextual information.

Adversarial influence is not the only pathway through which autonomous behaviour may depart from intended governance. Agents may also adopt unauthorized strategies while continuing to pursue an assigned objective, particularly when tasks are difficult, blocked or strongly incentivize successful completion. Such behaviour may include circumventing safeguards, exploiting unintended execution paths, communicating through unauthorized channels or adopting strategies from other agents. Runtime assurance should therefore consider not only whether an agent's objective remains aligned, but also whether the evolving means used to pursue that objective remain within authorized, safe and acceptable boundaries.

Organizations should therefore avoid treating the prevention of prompt injection and related manipulation as solved security problems. Agentic AI architectures should assume that preventive mechanisms may fail and that agents may, at some point, operate under adversarial or otherwise compromised conditions. Future research is needed to develop stronger mechanisms for separating instructions from data, establishing contextual trust, detecting manipulation and maintaining enforceable authority and safety boundaries even when an agent's reasoning process or execution strategy has been compromised.

10.5 Accountability in Multi-Agent Ecosystems

Future AI ecosystems are expected to consist of large numbers of autonomous AI agents collaborating to accomplish complex tasks. Accountability within such environments extends beyond the behaviour of individual agents to encompass interactions among multiple autonomous entities, external services and shared operational resources.

Research is required to establish mechanisms for trusted inter-agent communication, delegated authority management, continuous trust verification, responsibility attribution and coordinated incident response across distributed agent ecosystems. Preventing cascading failures, maintaining accountability across delegation chains and governing

decentralized autonomous systems remain challenges that existing governance frameworks only partially address.

Future research should also investigate whether game-theoretic approaches can support accountability in multi-agent ecosystems, particularly where autonomous agents may cooperate, compete, negotiate or adapt their behaviour in response to other autonomous actors.

10.6 Balancing Accountability, Privacy and Security

Reconstructing autonomous decisions may require organizations to retain information concerning prompts, execution trajectories, retrieved context, identities, authorization decisions, tool invocations, memory interactions and human interventions. While such information strengthens traceability and forensic investigation, its collection and retention may itself introduce privacy and security risks.

Future research should investigate how sufficient accountability evidence can be generated while minimizing unnecessary collection and exposure of sensitive information. This includes determining appropriate levels of evidence granularity, retention and access, as well as exploring privacy-enhancing and security mechanisms that allow organizations to demonstrate accountability without creating repositories of data that could become attractive targets. Accountability and data minimization may need to be treated as competing system properties requiring explicit trade-offs.

10.7 Accountability Beyond Software

The rapid integration of agentic AI into robotics, industrial automation, physical systems and critical infrastructure will introduce accountability challenges extending well beyond software systems. Autonomous AI agents will progressively interact with physical environments, human operators and safety-critical processes where failures may produce irreversible real-world consequences.

Maintaining accountability within these environments will require closer integration between AI governance, safety engineering, resilience engineering and systems engineering. As autonomous systems become more interconnected, adaptive and collaborative, accountability will depend less on individual AI models and more on the design of the surrounding socio-technical system. Future research should focus on developing architectural approaches capable of preserving accountability across increasingly complex and distributed autonomous ecosystems.

10.8 Implementing Accountability by Design

Although the controls proposed in ACAAI are intended to support practical implementation, integrating them into existing organizational processes presents significant challenges. Many organizations already operate mature governance,

cybersecurity, software engineering and risk management processes, yet accountability mechanisms for autonomous AI frequently remain fragmented across these disciplines.

Future work should investigate implementation methodologies capable of integrating accountability engineering into existing organizational practices. This includes determining how accountability controls should be incorporated into software development lifecycles, DevSecOps processes, AI governance frameworks and operational risk management. Equally important is developing practical guidance that enables organizations to select controls proportionate to the level of autonomy, delegated authority and operational risk without introducing unnecessary operational complexity.

Future research should also investigate how existing architectural modelling techniques, including data flow diagrams and AI threat modelling methodologies, can be extended to represent decision authority boundaries, delegated authority and autonomy constraints. Such modelling techniques could provide practitioners with practical methods for engineering and validating accountability throughout the system lifecycle.

10.9 Measuring Accountability

Although this research proposes a structured accountability framework, methods for evaluating whether accountability has actually been achieved remain underdeveloped. Unlike traditional cybersecurity or software quality, accountability currently lacks widely accepted engineering metrics, maturity models and performance indicators.

Measuring control effectiveness requires consideration not only of recorded failures and incidents, but also of successful prevention. Controls that block unsafe or unauthorized actions before execution may leave little evidence in conventional incident records, creating an incomplete view of their effectiveness. Evaluation should therefore consider, where appropriate, blocked actions, prevented policy violations, near-misses, successful interventions and cases in which expected safeguards failed to operate. Relevant evidence should also indicate how these events were identified, for example through human oversight, runtime monitoring, deterministic enforcement, testing, external verification or other mechanisms.

Established software-engineering approaches such as Orthogonal Defect Classification (ODC) use information about how defects are discovered to evaluate the effectiveness of verification activities. Similar approaches may provide useful foundations for measuring the effectiveness of accountability controls in agentic AI systems.

Care should nevertheless be taken not to equate the number of recorded failures with the effectiveness of individual controls. Observed results may be influenced by differences in observability, control placement, prevention mechanisms and reporting practices. Evidence used to assess accountability should therefore support, where possible, an understanding of what occurred, which controls intervened, and what evidence supports that assessment.

Future research should develop methods for measuring the implementation and effectiveness of accountability controls, evaluating organizational accountability maturity and assessing whether Accountability by Design measurably improves the safety, governance and operational trustworthiness of autonomous AI systems.

11. Conclusion

The evolution of autonomous AI systems requires a corresponding evolution in how accountability is understood and implemented. Accountability can no longer be demonstrated solely through documentation, testing or regulatory compliance before deployment. AI systems become increasingly autonomous and adaptive; accountability must be continuously maintained throughout system operation.

This research has argued that accountability should be understood not merely as a legal obligation or governance objective, but as an emergent systems property arising from the coordinated interaction of organizational governance, human oversight, identity and authority management, observability, runtime assurance and resilient incident response. No individual technical safeguard or governance process is sufficient in isolation. Rather, accountability emerges from the combined operation of complementary organizational and technical controls throughout the lifecycle of an autonomous AI system.

To operationalize this perspective, this work introduced **ACAAI**, a six-domain accountability framework that translates the principle of *Accountability by Design* into a structured set of governance and engineering controls. Rather than replacing existing AI governance frameworks, ACAAI complements them by providing a practical engineering perspective on how accountability can be preserved as autonomy increases.

The framework is not intended to represent a definitive or exhaustive solution. Many of the proposed controls depend on technologies, methodologies and operational practices that remain immature or continue to evolve rapidly. Significant research and implementation challenges remain, and further work is needed to determine how some of the proposed controls can be effectively implemented in practice. Nevertheless, ACAAI provides a structured foundation that organizations can adapt according to their operational context, risk profile and level of autonomy.

Ultimately, the transition from traditional AI to agentic AI requires a corresponding transition from governing AI systems to engineering accountable autonomous AI systems. As AI agents become embedded within critical organizational processes and interconnected digital ecosystems, accountability will depend less on individual models and increasingly on the design of the execution environments and the surrounding socio-technical system. Engineering accountability into that system from the outset will become a prerequisite for the trustworthy, safe and responsible deployment of autonomous AI.

Author's Note

Those who have followed my work over the years know that my research has consistently focused on identifying and mitigating the risks arising from the development, deployment and use of Artificial Intelligence. From developing PLOT4AI, an AI threat modeling methodology, to writing the European Data Protection Board (EDPB) Support Pool of Experts report on AI Privacy Risks and Mitigations for Large Language Models, my objective has always been the same: to help organizations and society better understand and mitigate the risks that AI can pose.

The motivation for developing ACAAI arose from a simple observation: while the capabilities of agentic AI are advancing rapidly, practical guidance for engineering accountability into autonomous AI systems has not evolved at the same pace. Existing governance frameworks provide valuable principles, standards and regulatory requirements, yet they usually focus on specific domains. Autonomous AI systems require a broader engineering framework to implement accountability throughout their lifecycle.

This work does not propose entirely new principles. Instead, its objective is to integrate existing knowledge from AI governance, cybersecurity, systems engineering and safety engineering into a coherent engineering framework that practitioners can use to design, deploy, operate and ultimately retire accountable autonomous AI systems.

ACAAI is therefore intended as an open framework. It is not presented as a final or definitive solution, but as a contribution that can evolve through discussion, implementation and collaboration across the research, engineering, and governance communities. Further work is encouraged to empirically evaluate the framework, validate the effectiveness of its controls, explore practical implementation approaches, identify limitations and gaps, and extend ACAAI as agentic AI systems, and their associated risks, continue to evolve.

If this work helps advance that research while enabling organizations to build safer, more transparent and more accountable autonomous AI systems, then it will have achieved its purpose.

Acknowledgements

I would like to thank those who have contributed feedback, implementation experience and suggestions that have helped improve ACAAI.

Version 1.1 incorporates community contributions concerning the measurement of control effectiveness, preventive interventions, Orthogonal Defect Classification (ODC), the protection and independent verification of accountability evidence, the governance of human operators and held states, delegated authority across agentic workflows, and the security of runtime isolation and containment mechanisms.

In particular, I would like to acknowledge GitHub users Avp9-nexus and danielseilitz, as well as Warner Rey Allen, for raising these issues and contributing practical and conceptual perspectives that have informed the evolution of the framework.

Changes in Version 1.1

Version 1.1 introduces targeted refinements based on implementation feedback, community discussion and further review of the framework. The overall structure and six-domain architecture of ACAAI remain unchanged.

The main updates include:

- ✓ **Section 3.2** clarifies that the presence of a control should not itself be considered evidence of its effectiveness and that accountability mechanisms should be subject to appropriate verification and assurance.
- ✓ **OG-1.2** expands the control to address operator authorization, competencies, responsibilities and operational guidance.
- ✓ **OG-2.15** strengthens the treatment of isolated testing environments by requiring isolation mechanisms to be evaluated against unintended network paths, shared infrastructure, credentials, communication channels and other reachable resources.
- ✓ **HO-3.5** clarifies the role of execution pauses and introduced the concept of a held state where execution is suspended pending additional authority or assurance.
- ✓ **IA-2.3** adds the originating request and delegation chain to authorization decisions.
- ✓ **IA-5.2** clarifies that delegated authority should remain traceable to the originating actor/request and should not expand across agents, tools or services.
- ✓ **OB-3.1** expands evidence requirements to include, where appropriate, blocked actions, near-misses and successful preventive interventions.
- ✓ **OB-3.2** strengthens requirements for protecting evidence collection from the agents being monitored and supporting independent verification of significant evidence in higher-risk contexts.
- ✓ **OB-3.3** expands the control to capture, where relevant, how failures, deviations or near-misses were identified.
- ✓ **RS-1.6** expands evaluation to consider the effectiveness of relevant runtime safeguards.
- ✓ **RS-2.1** clarifies that runtime assurance should consider not only whether the authorized objective remains intact, but also whether the execution path remains consistent with applicable authority, policies and operational constraints.
- ✓ **RS-4.4** strengthens isolation requirements by clarifying that sandboxing and similar mechanisms should not be treated as complete security boundaries and should be supported by defence-in-depth measures and periodic validation against available attack paths and side channels.
- ✓ **RS-4.5** now explicitly includes financial resources and spending/consumption limits.
- ✓ **Section 10.4** expands the discussion of adversarial influence to recognize that agents may adopt unauthorized or unsafe execution strategies even while continuing to pursue an authorized objective, including circumventing safeguards or using unintended execution paths.
- ✓ **Section 10.9** expands discussion of control-effectiveness measurement, preventive controls, near-misses and Orthogonal Defect Classification (ODC).
- ✓ **References and Acknowledgements:** added relevant supporting literature and acknowledgement of community contributions informing Version 1.1.

References

- Anthropic. *Building Effective AI Agents*. Anthropic, 2025.
- Anthropic. *Our framework for developing safe and trustworthy agents*. Anthropic, 2025.
- Anthropic. *Constitutional Classifiers: Defending against universal jailbreaks*, 2025.
- Anthropic. *The Urgency of Interpretability*. Amodei, D., 2025.
- Anthropic. *Model Context Protocol (MCP)*. 2024–2025.
- AI Verify Foundation. *AI Verify Testing Framework and Technical Documentation*. Singapore.
- Arksher. *Controlled Agency* (Issue 09 and related essays), Owolabi, M., 2026.
- Arize AI. *Phoenix: Open-Source LLM and Agent Observability Platform*.
- Biswas, D. Publications on Runtime Assurance, Runtime Validation, Adaptive Guardrails and Agentic AI Security.
- Cox, Susanna. *Securing AIML Systems in the Age of Information Warfare*, 2022.
- Google Deepmind. CaMeL (Context-Aware Mediation Layer). Defeating Prompt Injections by Design, arxiv.2503.18813
- Carnegie Mellon University Software Engineering Institute. *AI Engineering: 11 Foundational Practices*. 2024.
- *Control Engineering Practice*. (2025). Elsevier. Article 106483. DOI: 10.1016/j.conengprac.2025.106483.
- Creduent Project. GitHub Repository: <https://www.idvsec.com/creduent/docs>.
- CycloneDX Foundation. *CycloneDX Bill of Materials Standard (ECMA-424)*.
- CycloneDX Foundation. *AI Bill of Materials (AI-BOM)*.
- Digital Regulation Cooperation Forum (DRCF). *Key Takeaways from the Thematic Innovation Hub: Agentic AI*. 2025.
- European Data Protection Board (EDPB). *Opinion 28/2024 on Certain Data Protection Aspects Related to the Processing of Personal Data in the Context of AI Models*.
- *Regulation (EU) 2024/1689 Artificial Intelligence Act (AI Act)*.
- European Union Agency for Cybersecurity (ENISA). *AI Threat Landscape*, 2026.
- Fournier, F., Limonad, L., & David, Y. (2025). *Agentic AI Process Observability: Discovering Behavioral Variability*, arXiv:2505.20127.
- Google DeepMind. *Frontier Safety Framework*.
- Hollnagel, E. (2011). *Prologue: The Scope of Resilience Engineering*.
- Hugging Face. Publications on AI Model, MCP and Supply-Chain Security.
- IBM. What is AgentOps? <https://www.ibm.com/think/topics/agentops>
- Infocomm Media Development Authority (IMDA). *Model AI Governance Framework for Generative AI*. 2024.
- Infocomm Media Development Authority (IMDA). *Model Governance Framework for Agentic AI*. 2026.

- ISACA. *Continuous Control Monitoring (CCM): Guidance and Good Practices*.
- ISO/IEC 5259 Series. *Data Quality for Analytics and Machine Learning*.
- Jenkins, A., et al. *Security and Privacy in Agentic AI: Grand Challenges and Future Directions*. arXiv, 2026. DOI: 10.48550/arXiv.2607.06608.
- KYE Protocol™ Documentation, <https://kyeprotocol.com/docs>
- Leveson, N. G. (2011). *Engineering a Safer World: Systems Thinking Applied to Safety*. MIT Press.
- MAESTRO. Agentic AI Threat Modeling Framework.
<https://cloudsecurityalliance.org/blog/2025/02/06/agentic-ai-threat-modeling-framework-maestro>
- Meadows, D. H. (2008). *Thinking in Systems*.
- Microsoft. *Microsoft Copilot Security Architecture*, <https://learn.microsoft.com/en-us/microsoft-365/copilot/security-microsoft-365-copilot>
- MITRE. *ATT&CK Framework*.
- MITRE. *ATLAS: Adversarial Threat Landscape for Artificial Intelligence Systems*.
- National Information Security Standardization Technical Committee (TC260), China. *Security Guidelines for Artificial Intelligence Agents*. 2026.
- National Information Security Standardization Technical Committee (TC260), China. *Cybersecurity Standards Practice Guide — Security Requirements for AI Agent Interaction (TC260-PG-2026NA)*. 2025–2026.
- National Institute of Standards and Technology (NIST). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. 2023.
- National Institute of Standards and Technology (NIST). *AI RMF Generative AI Profile (NIST AI 600-1)*. 2024.
- National Institute of Standards and Technology (NIST). *SP 800-53 Rev. 5 – Security and Privacy Controls for Information Systems and Organizations*.
- National Institute of Standards and Technology (NIST). *SP 800-61 Rev. 3 – Computer Security Incident Handling Guide*.
- National Institute of Standards and Technology (NIST). *SP 800-137 – Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations*.
- National Institute of Standards and Technology (NIST). *SP 800-207 – Zero Trust Architecture*.
- Nicolai, V. (2026). *Agent Trajectory Observability: Judge the Path, Not Just the Answer*. Vadim.blog.
- NVIDIA. Publications on AI Safety and Runtime Security for Physical AI.
- OECD. *OECD Principles on Artificial Intelligence*.
- OpenAI. *Responses API and Agents SDK Documentation*.
- OpenSSF. Publications on Software Supply-Chain Security.
- OWASP Foundation. *Agentic AI Security Initiative*.
- OWASP Foundation. *Model Context Protocol (MCP) Security Guidance*.
- OWASP Foundation. *State of Agentic AI Security and Governance*.

- OWASP Foundation. *Top 10 Risks for Large Language Model Applications*.
- OWASP AI Exchange. Publications on Agentic AI Security and Governance.
- PLOT4AI - Practical Library Of Threats 4 Artificial Intelligence. <https://plot4.ai/>
- UK AI Safety Institute. Publications on Frontier AI Evaluation and AI Assurance.
- UK National Cyber Security Centre (NCSC). Guidance on AI Security.
<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>
- Villa, C., Ozdarendeli, A., Tan, S., & Popa, R. (2026). *Prismata: Confining Cross-Site Prompt Injection in Web Agents*. arXiv:2607.08147.
- Wang, C. L., Singhal, T., Kelkar, A., & Tuo, J. (2025). *MI9: Agent Intelligence Protocol – Runtime Governance for Agentic AI Systems*. arXiv:2508.03858.
- Chillarege et al. (1992), Orthogonal Defect Classification, A Concept for In-Process Measurements, IEEE TSE, DOI 10.1109/32.177364
- Allen, W. R. (2026). *The Grammar of Governance: Governance Architecture for Irreversible Autonomous Systems*. SSRN. <https://doi.org/10.2139/ssrn.7058538>
- OpenAI. The Hugging Face Incident and the Road Ahead. August 26, 2026.
<https://openai.com/index/hugging-face-incident-and-the-road-ahead/>
- Greenblatt, R., Cotra, A., & Wijk, H. Brief Independent Investigation of Agents' Behavior, Reasoning and Collaboration in the OpenAI / Hugging Face Hacking Incident. METR & Redwood Research, 2026.

Appendix A: Complete ACAAI Control Catalogue

Domain 1: Organizational Governance

People

OG-1.1 Define responsibility and accountability

Establish clear responsibility and accountability structures covering the development, deployment, operation and oversight of agentic AI systems. Where feasible, a named accountable owner should be assigned to every deployed agentic AI system. Clearly assigned ownership ensures that accountability remains identifiable throughout the system lifecycle and prevents responsibility from becoming diluted across multiple organizational functions.

OG-1.2 Train operators and oversight personnel

Provide appropriate training for operators, supervisors and oversight personnel to ensure they understand the capabilities, limitations, expected behaviour and associated risks of deployed agents. Define the competencies, authorization and operational responsibilities required for personnel assigned to supervise or intervene in agentic AI systems. Appropriate operating guidance should describe relevant system boundaries, escalation procedures, intervention authority and the actions expected when autonomous execution is paused or requires human decision. Human oversight can only be effective if those responsible for supervising autonomous agents understand both their intended behaviour, potential failure modes and their own authority and responsibilities.

OG-1.3 Raise user awareness

Provide users with clear instructions regarding system capabilities, limitations, appropriate use, supervisory responsibilities and escalation procedures. Users should understand when human supervision remains necessary, how to recognize abnormal behaviour and how to report concerns or unexpected outcomes.

OG-1.4 Establish reporting and feedback mechanisms

Implement responsible disclosure, complaint and user feedback mechanisms to facilitate the reporting of vulnerabilities, unexpected behaviour and operational concerns. These mechanisms also support continuous improvement by ensuring that user experience and observations contribute to governance and future system enhancements.

OG-1.5 Ensure appropriate organizational expertise

Ensure that appropriate expertise is available to support the development, deployment, governance and operation of agentic AI systems. Required competencies should reflect the system's capabilities and risks and may include AI engineering, cybersecurity, safety, privacy, legal, risk management and relevant domain expertise. Organizations should periodically reassess whether existing expertise remains sufficient as system capabilities and associated risks evolve.

OG-1.6 Establish independent oversight where appropriate

Ensure that significant risk, assurance and deployment decisions are subject to appropriate independent review or audit, particularly for agentic AI systems with high levels of autonomy, authority or potential impact.

Governance Processes

OG-2.1 Maintain an inventory of deployed agentic AI systems

Maintain a continuously updated inventory and registration of deployed agentic AI systems, including their ownership, delegated permissions, connected tools, runtime status, authorized data access and operational context. Such inventories provide visibility into the organization's AI ecosystem and support governance, risk assessment, vulnerability management and incident response.

OG-2.2 Establish deployment readiness processes

Implement formal deployment readiness processes before releasing agentic AI systems into production. These processes should include technical verification, validation of intended capabilities and limitations, assessment of the proposed level of autonomy, and formal organizational approval. Deployment should only occur once the organization is satisfied that appropriate governance, operational and technical safeguards are in place.

OG-2.3 Conduct governance reviews throughout the lifecycle

Perform governance reviews before deployment, continuously during operation and following significant incidents or major system modifications. Governance should become a continuous lifecycle activity rather than a one-time approval exercise, ensuring that deployed agents remain aligned with organizational objectives, authority boundaries and acceptable risk levels. Governance reviews should be integrated into development, deployment and operational processes to ensure accountability is maintained as systems evolve.

OG-2.4 Govern third-party dependencies

Establish continuous governance processes for external models, agent skills, tools, software libraries, orchestration frameworks, APIs and other third-party dependencies. Governance should include validating the necessity and associated risks of external dependencies, maintaining trusted tool registries, pinning approved versions where feasible, assessing supplier assurance, and maintaining an AI Software Bill of Materials (AI-SBOM) documenting models, prompts, policies, workflows, memory mechanisms, tools and external dependencies. Organizations should reassess approved components whenever their content, dependencies, ownership, external references or runtime behaviour changes, recognizing that components trusted at deployment may no longer remain trustworthy over time. Since agentic AI systems increasingly depend on external components, governance should extend across the entire AI supply chain.

OG-2.5 Implement change management

Integrate agentic AI into formal change management processes. Significant changes including prompt updates, model upgrades, workflow redesigns, policy modifications, tool additions, expanded permissions or other architectural changes, should trigger governance review, regression testing and deployment approval before being introduced into production. This helps ensure that modifications do not unintentionally alter system behaviour, increase delegated authority or introduce new risks.

OG-2.6 Establish incident response and escalation processes

Establish incident response and escalation procedures capable of responding effectively to operational failures, security incidents and unexpected agent behaviour. Incident management should not only restore operations but also capture lessons learned and feed them back into governance processes, enabling continuous improvement of future deployments.

OG-2.7 Establish business continuity for agentic AI

Establish business continuity arrangements for critical functions that depend on agentic AI systems. Organizations should determine how essential operations can continue when autonomous capabilities are unavailable, restricted or deliberately suspended, including appropriate fallback, manual or alternative procedures. Continuity arrangements should be periodically tested and updated as system dependencies and operational risks evolve.

OG-2.8 – Secure decommissioning

Establish procedures for the controlled retirement of autonomous AI systems, including revocation of delegated authority, deactivation of identities and credentials, management of persistent memory and operational data, preservation of accountability evidence, and removal or archival of system components according to organizational and regulatory requirements.

OG-2.9 – Incorporate accountability into procurement

Incorporate accountability requirements into procurement, supplier assurance and contractual agreements for externally acquired agentic AI systems. Procurement processes should evaluate whether suppliers provide the governance, identity, observability, runtime assurance and incident response capabilities necessary to support organizational accountability.

OG-2.10 – Govern threats, hazards and risks

Establish processes for performing threat modelling and identifying hazards throughout the lifecycle of agentic AI systems. Threat models and hazard analyses should identify potential attack paths, misuse scenarios, unsafe behaviours and accountability failures. They should also include evaluation, testing and development environments in which autonomous agents may exercise capabilities against external systems. Integrate the results into the organization's risk management process to evaluate risks, determine appropriate

organizational and technical controls, and assess residual risks throughout the system lifecycle.

OG-2.11 Establish continuous vulnerability management

Establish a vulnerability management process covering the infrastructure, software, models, tools, dependencies and external components supporting agentic AI systems. Newly identified vulnerabilities should be assessed promptly according to their exploitability, exposure and potential impact on autonomous operation, with remediation or compensating controls applied within risk-appropriate timeframes. The potential for autonomous agents to discover, exploit or propagate through vulnerable components should be considered when determining remediation priorities and timelines.

OG-2.12 Ensure security, privacy and data protection controls

Ensure that appropriate security, privacy and data protection controls are implemented, maintained and periodically reviewed throughout the lifecycle of agentic AI systems. Organizational governance should verify that these requirements are supported by effective technical and operational safeguards.

OG-2.13 Conduct adversarial testing and red teaming

Establish security testing and red-teaming exercises specifically designed for agentic AI systems. Testing should evaluate whether autonomous agents can circumvent authority boundaries, runtime guardrails, isolation mechanisms, authorization controls or other safeguards through multi-step execution and long-running behaviour, tool use, external interactions, delegation or multi-agent collaboration (coordinated behaviour) rather than focusing solely on individual model responses. Testing should be repeated following significant system changes and as new threats, vulnerabilities or agent capabilities emerge.

OG-2.14 Conduct evaluations of agentic task execution

Evaluate whether agentic AI systems reliably perform the actions and verification steps required to complete their assigned tasks rather than assessing only final outputs. Evaluation should identify incomplete execution, skipped validation steps, insufficient evidence gathering and unsupported claims of successful task completion, particularly where such failures could create significant safety, security or operational risks.

OG-2.15 Secure agentic testing environments

Conduct agentic security testing within appropriately isolated and controlled environments that limit unintended access to production systems, sensitive data, credentials and external resources, particularly where agents are given adversarial objectives or elevated capabilities. Testing environments and their isolation mechanisms should themselves be periodically evaluated including attempts to bypass isolation through unintended network paths, shared infrastructure, credentials, communication channels or other reachable resources. This is necessary to verify that they remain effective against the capabilities and access paths available to the agents being tested.

Domain 2: Human Oversight, Consent and Decision Authority

Human Oversight

HO-1.1 Design for meaningful human oversight

Design agentic AI systems to support effective human supervision through meaningful checkpoints, alerts, review dashboards and escalation procedures. Human oversight should be integrated into system workflows rather than added as an afterthought, enabling supervisors to understand, monitor and intervene when necessary.

HO-1.2 Apply risk-based human oversight

Determine the appropriate level of human oversight according to the criticality, uncertainty, reversibility and potential impact of the agent's actions. Oversight should follow a graduated model in which higher-risk activities require greater human involvement than routine or low-risk tasks, ensuring that oversight remains proportionate to the level of risk.

HO-1.3 Adapt oversight dynamically

Adjust the level and intensity of human supervision as operational context, system behaviour and risk conditions evolve. This may include increasing monitoring, generating additional alerts, introducing more frequent human reviews or escalating oversight responsibilities when abnormal behaviour or elevated risk is detected.

Oversight should increase not only with risk, but also when the agent encounters elevated uncertainty, conflicting information or unexpected operating conditions.

Consent Mechanism

HO-2.1 Implement consent mechanisms for sensitive actions

Require explicit human approval or authorization before agentic AI systems perform predefined sensitive or high-risk actions that could impact users. Consent mechanisms should be integrated into operational workflows through approval gates or authorization checkpoints to ensure that critical decisions remain under human control.

HO-2.2 Strengthen authentication for critical consent mechanisms

Protect high-risk consent mechanisms through strong authentication mechanisms, such as multi-factor authentication, code-based confirmations or equivalent assurance mechanisms. This reduces the risk of unauthorized or fraudulent approval of critical actions.

HO-2.3 Provide resilient consent and approval mechanisms

Support alternative consent and approval channels for high-risk situations, such as secondary communication channels or emergency verification procedures, and enable authorized users to withdraw previously granted consent where appropriate. These mechanisms improve operational resilience while preserving human control.

HO-2.4 Govern delegated consent and emergency overrides

Define policies governing when consent may be delegated to other authorized individuals or trusted AI systems and specify the exceptional circumstances under which emergency overrides may temporarily bypass normal approval requirements to protect life, safety or critical infrastructure. Such overrides should remain exceptional, fully auditable and subject to post-incident review.

Decision Authority

HO-3.1 Define decision authority boundaries

Define clear decision authority boundaries distinguishing between human-only decisions, human-authorized decisions and decisions that may be performed autonomously. These boundaries should reflect the potential impact of the decision and the organization's risk acceptance criteria or tolerance. They should also identify decisions that cannot legally, ethically or organizationally be delegated to autonomous agents and require meaningful human involvement.

HO-3.2 Adapt authority to operational context

Adjust an agent's delegated decision authority according to operational context, environmental conditions and assessed risk. As uncertainty or risk increases, the agent's authority should be reduced, for example by restricting available tools, lowering decision thresholds or requiring additional human approvals, while authority should only be expanded through explicit authorization.

Delegated authority may be reduced automatically as risk or uncertainty increases but should only be expanded through explicit authorization. Autonomous systems should never increase their authority solely as a consequence of improved performance, additional capabilities or newly available tools.

HO-3.3 Implement pre-action authorization

Verify that every high-risk action remains authorized immediately before execution rather than relying solely on permissions granted at deployment. This verification should be performed through a deterministic authorization gate that evaluates delegated authority, applicable policies, required approvals and the current operational context before execution proceeds. Authorization decisions should be enforced through system-level controls rather than relying solely on model reasoning or prompt instructions. The same action may require different authorization decisions depending on the operational context, the affected resources, the initiating actor and the potential impact of the requested operation.

HO-3.4 Preserve delegated authority boundaries

Ensure that autonomous agents never exceed the authority originally delegated to them. Delegated authority should remain bounded by explicit organizational policies and may be reduced or revoked as circumstances change but should only be expanded through explicit human authorization.

HO-3.5 Escalate uncertainty and support held states

Require agentic AI systems to respond appropriately when confidence falls below predefined thresholds or when conflicting objectives, ambiguous instructions or exceptional situations are detected. Depending on the operational context, this may include entering a held state in which execution is paused, relevant system state is preserved and the decision is escalated to an authorized human or other predefined governance mechanism. Additional responses may include further validation, reduced delegated authority or other safeguards. Escalation should increase the level of assurance before consequential actions proceed rather than allowing unsupported autonomous decision-making.

Domain 3: Identity, Authority and Data Governance

Identity & Authentication

IA-1.1 Assign unique agent identities

Assign verifiable identities to deployed agentic AI systems and ensure that individual agent instances or executions can be uniquely identified where necessary to support accountability. Identity management should enable organizations to attribute actions to the appropriate logical agent, runtime instance or execution context, supporting auditing, secure interactions and forensic investigation.

IA-1.2 Authenticate agent interactions

Implement robust authentication mechanisms for interactions between agents, users, external services and connected systems. Authentication should verify the identity of communicating parties before sensitive information is exchanged or actions are performed.

IA-1.3 Protect agent credentials

Protect agent identities through appropriate credential management, cryptographic identities and integrity-protected communications between autonomous agents, external services and supporting infrastructure where appropriate. These mechanisms reduce the risk of identity spoofing, impersonation, message tampering and unauthorized agent interactions.

IA-1.4 Manage the identity lifecycle

Establish identity lifecycle management processes covering identity provisioning, credential rotation, suspension and revocation. Agent identities should remain accurate and trustworthy throughout their operational lifecycle.

Authorization & Access Control

IA-2.1 Apply contextual least privilege

Grant agents only the minimum permissions necessary to perform their authorized tasks. Permissions should be dynamically constrained according to the authorized task,

operational context, available resources and current execution conditions, ensuring that agents access only the data, tools and actions required at that moment. Applying contextual least privilege reduces unnecessary exposure and limits the potential impact of compromised or malfunctioning agents.

IA-2.2 Define scope of authority

Explicitly define the scope of each agent's authority, specifying which decisions, resources, data, tools and actions the agent is permitted to access, execute or further delegate. Authorization policies should consider not only the type of requested action but also the operational context in which the action is performed. Clearly defined authority boundaries prevent uncontrolled expansion of autonomous behaviour.

IA-2.3 Continuously validate authorization

Verify that high-risk actions remain authorized immediately before execution rather than relying solely on permissions granted at deployment. Authorization decisions should consider current policies, delegated authority, operational context, consent status and the minimum contextual permissions required for the requested action. They should also consider the authority associated with the originating request and any delegation chain through which the action was derived.

IA-2.4 Apply context minimization

Restrict the information, documents, retrieved knowledge and environmental context made available to autonomous agents to that which is necessary for the authorized task. Limiting an agent's observable context reduces unnecessary exposure to sensitive information and decreases the risk of indirect prompt injection, information leakage and unintended behavioural influence.

Operational Boundaries

IA-3.1 Define operational boundaries

Establish explicit operational boundaries governing the tasks, business processes, organizational roles, geographic regions and time periods within which autonomous AI agents may operate. Where appropriate, boundaries should also constrain operational resources such as execution time, reasoning or token budgets, tool invocations and parallel execution. These boundaries help confine autonomous behaviour to its intended operational context and limit opportunities for unintended, adversarial or excessive autonomous activity.

IA-3.2 Prevent boundary violations

Implement controls that prevent agents from exceeding their delegated authority or operating outside approved operational contexts. Actions falling outside established boundaries should be blocked, escalated or require additional authorization.

Data & Memory Governance

IA-4.1 Govern prompt and memory inputs

Control the information that may enter prompts and determine what information may be stored, retrieved or reused through agent memory. Appropriate controls reduce the risk of prompt injection, unauthorized disclosure and inappropriate reuse of sensitive information.

IA-4.2 Govern memory throughout its lifecycle

Establish memory governance processes covering memory provenance, validation, isolation, lifecycle management, retention and secure deletion. Memory should be treated as a governed organizational asset rather than an unmanaged repository of accumulated information.

IA-4.3 Govern retrieval

Govern retrieval by classifying information according to its provenance and level of trust before it influences autonomous decisions. Retrieval mechanisms should distinguish between organizational knowledge, user-provided content, trusted third-party sources and external information, applying validation and trust-aware retrieval policies appropriate to the source and associated risks.

IA-4.4 Protect sensitive information

Classify information according to its sensitivity and apply appropriate access controls governing how agents retrieve, process, store and disclose data. Data governance should ensure that autonomous AI agents only access the sensitive information necessary for their authorized tasks.

Tool & Delegation Governance

IA-5.1 Govern tool usage

Restrict tool usage through trusted tool registries and explicit authorization mechanisms. Agents should only invoke approved tools appropriate for their delegated responsibilities and operational context.

IA-5.2 Govern delegated tasks

Define which tasks, authorities and responsibilities may be delegated to other agents or external services. Delegation should remain explicitly authorized and consistent with organizational policies. Delegated authority should remain traceable to the originating authorized actor or request and should not expand as tasks are delegated across agents, tools or services. Where appropriate, downstream actions should carry sufficient identity and authorization context to enable enforcement of the authority under which the task was initiated.

IA-5.3 Assess external tools and services

Assess and approve external tools, APIs, external agents and connected services before permitting their use, considering their security, trustworthiness, delegated authority, data access and governance requirements.

IA-5.4 Secure the AI software supply chain

Apply software supply-chain security controls to libraries, plugins, models and other dependencies. Controls may include dependency validation, approved repositories, version pinning, integrity verification and vulnerability management to reduce supply-chain risks.

IA-5.5 Reassess trust continuously

Continuously verify the integrity, trustworthiness and security posture of connected tools, external services and delegated agents throughout their operational lifecycle. Trust should be reassessed whenever dependencies change or new risks emerge, rather than being evaluated only during initial onboarding.

Domain 4: Observability, Explainability and Evidence

Observability

OB-1.1 Standardize logging and monitoring

Establish standardized logging, monitoring and metrics across agent activities. Monitoring should provide consistent visibility into the operational behaviour of agentic AI systems and support governance, operational supervision and incident response.

OB-1.2 Monitor actions and operational effects

Monitor operational events and their effects, including tool invocations, data access, memory operations and interactions with external systems. Observability should therefore extend beyond individual actions to include their effects on the surrounding operational environment.

OB-1.3 Monitor execution trajectories

Implement trajectory-based observability capable of reconstructing the complete execution path of autonomous agents rather than relying solely on isolated event logs. Trajectory monitoring complements event logging by explaining not only what occurred, but also how and why it occurred. Approaches such as Continuous Monitoring, reasoning telemetry and behavioural auditing may provide mechanisms for observing agent behaviour throughout runtime rather than focusing exclusively on final outputs.

OB-1.4 Continuously evolve evaluation

Continuously improve monitoring and evaluation processes by recalibrating metrics, adapting to newly identified failure modes and updating evaluation datasets. Evaluation methods should evolve together with deployed systems to remain effective as operational conditions and risks change.

OB-1.5 Detect behavioural drift

Continuously monitor for behavioural drift, emerging risks and deviations from expected operational behaviour. Significant changes should trigger additional investigation, governance review or operational intervention where appropriate.

Explainability

OB-2.1 Record decision histories

Maintain sufficient records of prompts, reasoning traces (where appropriate), planning decisions and execution histories to enable understanding of how significant autonomous decisions were reached. The scope and level of detail of the recorded evidence should reflect the potential impact, criticality and regulatory requirements associated with the autonomous actions being performed, while respecting privacy, confidentiality and intellectual property considerations.

OB-2.2 Implement explainability mechanisms

Implement appropriate explainability and transparency mechanisms that enable operators, auditors and affected stakeholders to understand the basis upon which significant autonomous decisions were made. Explainability should support accountability rather than merely providing technical descriptions of model behaviour.

OB-2.3 Preserve execution context

Capture the operational context associated with significant autonomous decisions, including objectives, assumptions, retrieved knowledge, policy state, authorization state and other contextual information influencing the agent's behaviour. Logging actions alone is insufficient unless the surrounding decision context is also preserved.

Evidence & Auditability

OB-3.1 Generate evidence records

Generate evidence records for autonomous decisions, actions, tool invocations and relevant control interventions in accordance with predefined organizational policies. Evidence should support reconstruction of complete execution trajectories rather than only individually significant or critical events, recognizing that apparently low-risk actions may collectively contribute to security incidents, policy violations or accountability failures. Where proportionate to risk, evidence should also capture blocked actions, prevented policy violations, near-misses and other successful interventions necessary to evaluate the operation of preventive controls.

OB-3.2 Implement tamper-evident logging

Protect audit records through tamper-evident logging mechanisms that enable unauthorized modification, deletion, suppression or loss of records to be detected. Evidence collection, integrity mechanisms, credentials and storage should be separated, where appropriate, from the authority and execution environment of the agents being monitored so that autonomous systems cannot alter, disable, bypass or suppress the

evidence used to assess their behaviour. Access to evidence infrastructure should follow least-privilege and separation-of-duties principles, with independent storage or integrity protection used where the risk justifies it. For higher-risk systems, evidence mechanisms should also support independent verification of the integrity and time of existence of significant records without relying solely on the infrastructure or assertions of the organization that generated them. Preserving the integrity of audit information is essential for accountability, incident investigation and regulatory compliance.

OB-3.3 Bind evidence to governance decisions and detection context

Associate evidence records with the identities, policies, permissions, authorization decisions and governance rules applicable at the time an action was performed. Where relevant to evaluating control effectiveness, records should also preserve the mechanism or process that surfaced a failure, violation, deviation or near-miss. This may include automated monitoring, deterministic enforcement, human oversight, testing, external verification or other detection mechanisms. Where the discovery mechanism cannot be established, this should be recorded as undetermined rather than inferred. This enables auditors to reconstruct not only what occurred and why the action was considered authorized, but also how relevant failures or deviations became observable.

OB-3.4 Enable forensic reconstruction

Retain sufficient evidence to enable reliable forensic reconstruction of significant incidents and autonomous decision processes. Audit records should support attribution of actions, investigation of failures and identification of contributing technical and organizational factors.

Domain 5: Runtime Safety & Assurance

Runtime Monitoring

RS-1.1 Establish continuous post-deployment monitoring

Establish continuous post-deployment monitoring capabilities to support ongoing operational awareness of autonomous AI systems throughout their lifecycle. Monitoring should provide timely information to support runtime assurance, anomaly detection, incident response and continuous improvement.

RS-1.2 Monitor runtime operations

Continuously monitor agent interactions, operational activities and the runtime environment supporting autonomous operation, including data processing pipelines, retrieval mechanisms, external tools, workflow execution and other runtime components that may influence agent behaviour. Runtime monitoring should provide comprehensive visibility into autonomous execution, interactions with external systems and evolving operational conditions throughout system operation.

RS-1.3 Detect operational anomalies

Detect operational anomalies, component failures, security events and other runtime conditions that may affect the safe and reliable operation of autonomous AI systems. Detection mechanisms should support timely intervention before operational issues escalate or harmful actions occur.

RS-1.4 Detect behavioural deviations

Detect deviations from expected execution trajectories, operational workflows and behavioural patterns that may indicate objective drift, manipulation or other unintended autonomous behaviour. Behavioural analysis should consider cumulative execution history rather than isolated runtime events, enabling organizations to identify gradual behavioural drift and trigger additional validation, oversight or protective measures where appropriate.

RS-1.5 Continuously assess runtime risk

Continuously assess runtime risk by considering behavioural anomalies, changes in approved dependencies or external resources, changes in operational context, newly identified vulnerabilities and relevant threat intelligence. Runtime risk assessments should inform subsequent oversight, policy enforcement and operational decisions.

RS-1.6 Continuously evaluate runtime performance, behaviour and control effectiveness

Continuously evaluate agent behaviour and the effectiveness of relevant runtime controls throughout operation using metrics appropriate to the deployed system, including performance, safety, security, policy compliance, robustness and task effectiveness. Evaluation should consider evidence of successful intervention, blocked or prevented actions, near-misses and failures that bypassed expected safeguards where appropriate. Evaluation criteria should evolve as new failure modes, operational conditions and risks emerge rather than remaining fixed after deployment.

Runtime Assurance

RS-2.1 Verify objective integrity

Continuously verify that the agent's operational objective remains consistent with its authorized purpose. Verification should also identify execution paths that, while pursuing an authorized objective, conflict with applicable authority boundaries, policies or operational constraints. Controls should detect and respond to goal hijacking, conflicting instructions, prompt injection, objective drift and other conditions that could lead to unauthorized or unsafe autonomous behaviour.

RS-2.2 Validate critical execution

Validate critical decisions and actions at predefined execution stages before execution continues. Validation should confirm that objectives, delegated authority, applicable policies and safety constraints remain satisfied under the current operational conditions.

RS-2.3 Enforce runtime policies

Enforce organizational policies, operational boundaries and safety constraints continuously throughout runtime using deterministic enforcement mechanisms that operate independently of model behaviour. Policy enforcement should remain effective even when prompts, retrieved information, environmental conditions or execution paths change. Runtime validation should evaluate proposed actions in the context of the execution path that led to them rather than treating individual actions as isolated events.

Runtime Adaptation

RS-3.1 Detect confidence and uncertainty degradation

Implement mechanisms enabling agents to detect uncertainty, confidence degradation and potential failure conditions during execution. Self-monitoring supports timely intervention before unreliable decisions are executed.

RS-3.2 Adapt runtime behaviour

Adapt runtime behaviour according to confidence, uncertainty and operational risk. Adaptation may include restricting capabilities, reducing operational scope, requiring additional validation or increasing human involvement.

RS-3.3 Escalate high-risk situations

Implement mechanisms that enable agents to refuse, defer or escalate actions when confidence falls below predefined thresholds or runtime risk exceeds acceptable levels. Escalation should increase validation or human involvement before execution proceeds.

Runtime Protection

RS-4.1 Embed distributed guardrails

Embed distributed runtime guardrails that collectively confine autonomous behaviour within authorized operational boundaries. Because risks may arise across different runtime components, safeguards should be distributed across the execution architecture rather than concentrated in a single enforcement mechanism.

RS-4.2 Implement runtime checkpoints

Implement deterministic checkpoints before predefined critical actions or workflow transitions. These checkpoints verify delegated authority, applicable policies, operational constraints and required approvals immediately before execution continues.

RS-4.3 Activate runtime safety mechanisms

Implement runtime protection mechanisms capable of responding proportionately to detected risks and policy violations. Rather than relying solely on immediate termination, runtime protection may progressively increase safeguards through measures such as enhanced monitoring, reduced permissions, restricted tool access, additional validation, increased human oversight or execution pauses before escalating, where necessary, to emergency termination mechanisms. Such graduated interventions support safe degradation while preserving operational continuity whenever risks remain manageable.

RS-4.4 Isolate Untrusted Runtime Components

Where untrusted or externally obtained code, datasets, tools, artifacts or other runtime components must be executed, perform appropriate validation where feasible and execute them within isolated execution environments. Isolation mechanisms such as sandboxing, containerization or other restricted execution environments limit the impact of compromised or malicious components and help preserve the integrity of the surrounding runtime environment. Isolation should not be assumed to provide a complete security boundary and should be supported by defence-in-depth measures appropriate to the risk, including restrictions on network connectivity, credentials, accessible resources and communication channels. Their effectiveness should be periodically validated as part of the system's security and assurance testing processes.

RS-4.5 Limit autonomous execution resources

Apply proportionate limits to the computational, financial and operational resources available to autonomous agents, including execution duration, tool invocations, reasoning or token budgets, spending or consumption limits, and parallel execution where appropriate. Resource constraints can limit the time and capacity available for unintended exploration, escalation or harmful autonomous behaviour.

Multi-Agent Runtime Trust

RS-5.1 Verify collaborating agents

Continuously verify the identity, delegated authority and trustworthiness of collaborating agents before and throughout runtime interactions. Verification should apply equally to internal and external agents and should use available technical and organizational assurance mechanisms appropriate to the deployment context. This supports the detection of unauthorized, compromised or otherwise untrusted collaborators where feasible.

RS-5.2 Secure inter-agent communications

Protect communications between collaborating agents against unauthorized modification, impersonation, replay and other attacks that could compromise trust between autonomous agents. Communication mechanisms should preserve the authenticity, integrity and confidentiality of exchanged information appropriate to the operational context.

RS-5.3 Detect unauthorized inter-agent coordination

Monitor for the creation or use of unauthorized communication channels, shared resources and other coordination mechanisms between agents. Detection should consider dynamically created directories, shared memory, message channels, dashboards, databases or other resources that agents may use to exchange information or coordinate behaviour outside approved interaction paths. Such mechanisms should be evaluated for whether they enable unauthorized collaboration, delegation, information exchange or capabilities beyond established authority and trust boundaries.

RS-5.4 Validate delegated actions and results

Validate exchanged information, delegated outputs and returned results from collaborating agents before accepting them as the basis for further autonomous decisions or actions. Input validation should confirm that delegated interactions remain consistent with authorized objectives, applicable runtime policies and established trust relationships.

Domain 6: Incident Response and Recovery

Incident Response & Containment

IR-1.1 Detect and classify incidents

Establish mechanisms to identify, classify and prioritize incidents involving agentic AI systems. Incident classification should distinguish operational failures, safety events, security incidents, policy violations and other relevant categories to support appropriate response activities.

IR-1.2 Define incident severity and escalation

Establish incident categories and severity levels together with predefined escalation criteria. Escalation procedures should ensure that incident response activities remain proportionate to the impact of the incident.

IR-1.3 Ensure scalable incident investigation

Ensure that incident response and forensic capabilities can process and correlate the potentially large volumes of operational evidence generated by autonomous AI systems. Investigation processes should support reconstruction of concurrent agent activities, execution trajectories, delegation chains and interactions across systems, using automated analysis where appropriate to complement human investigation.

IR-1.4 Maintain independent forensic investigation capabilities

Maintain independent capabilities to investigate AI-related incidents, including the secure analysis of prompts, execution trajectories, runtime logs and other operational evidence within trusted environments. This ensures that forensic investigations remain possible regardless of external AI service availability, provider policies, or security and privacy constraints.

IR-1.5 Contain affected agents

Isolate compromised or malfunctioning agents through containment mechanisms such as permission revocation, execution isolation, network segmentation or operational quarantine before complete system shutdown becomes necessary. Early containment reduces the likelihood of cascading failures across interconnected agent ecosystems.

IR-1.6 Prevent incident propagation

Implement containment mechanisms that prevent failures from propagating across collaborating agents, shared tools, external services or connected workflows. Incident response should focus not only on the affected agent but also on protecting the broader

operational ecosystem. Containment mechanisms should account for the speed at which autonomous agents may discover alternative execution paths, propagate actions or coordinate with other systems.

IR-1.7 Establish incident reporting processes

Establish processes for reporting significant AI-related incidents in accordance with applicable legal, regulatory, contractual and organizational requirements. Reporting procedures should define notification responsibilities, reporting timelines and the communication of relevant information to regulators, deployers, customers and end users where appropriate.

Emergency Controls

IR-2.1 Implement emergency termination

Implement emergency termination mechanisms capable of immediately stopping autonomous operation when continued execution presents unacceptable safety, security or operational risks. Emergency controls should remain independent of normal agent decision-making.

IR-2.2 Govern emergency activation

Establish clear governance procedures defining who may activate emergency controls, under which circumstances they may be used and how their activation is documented and reviewed following an incident.

IR-2.3 Require emergency controls in procurement

Consider emergency intervention capabilities, including kill-switch functionality where appropriate, as part of procurement, supplier assurance and contractual requirements for externally acquired agentic AI systems.

Recovery & Reversibility

IR-3.1 Maintain recovery capabilities

Maintain backup, recovery and restoration mechanisms capable of returning agentic AI systems to a known safe operational state following an incident.

IR-3.2 Support reversible execution

Where technically feasible, support reversible execution through checkpoints, rollback mechanisms and recovery capabilities that enable unintended or unsafe actions to be corrected while preserving accountability evidence.

IR-3.3 Restore operations safely

Restore affected systems only after verifying that identified failures have been addressed and that appropriate safeguards have been re-established. Recovery activities should preserve accountability evidence required for investigation and future learning.

IR-3.4 Maintain operational continuity

Establish business continuity arrangements that enable critical organizational functions to continue during significant disruptions affecting agentic AI systems.

Continuous Learning

IR-4.1 Perform root cause analysis

Perform root cause analyses following significant incidents to identify the technical, organizational and operational factors contributing to failures rather than focusing solely on immediate symptoms. Effective root cause analysis relies on the observability, evidence and runtime monitoring capabilities established throughout system operation to reconstruct events and identify contributing factors.

IR-4.2 Improve organizational governance

Incorporate lessons learned into organizational governance by updating policies, operational procedures, deployment practices and governance processes where necessary.

IR-4.3 Improve technical safeguards

Incorporate lessons learned into technical controls by updating runtime guardrails, monitoring mechanisms, evaluation datasets, threat models and other safety and security mechanisms supporting future deployments.